



IT&OT Security

Universitat de Girona (UDG)

Guía de aplicación de metodología de ciberdiagnóstico para la detección de ciberincidentes en el Sector del Agua.

UDG-PR240560-E2.1



Informe redactado por Giuseppe Sciuto

Título:	Guía de aplicación de metodología de ciberdiagnóstico para la detección de ciberincidentes en el sector del agua
Informe número:	UDG-PR240560-E2.1
Oferta número:	2024-032464
Responsable técnico	Giuseppe Sciuto giuseppe.sciuto@eurecat.org
Responsable comercial	Jesus Boschmonart jesus.boschmonart@eurecat.org 682 93 01 94
Fecha:	01/06/2025
Cliente:	Universitat de Girona
Receptor:	Universitat DE GIRONA informacio@udg.edu 972418025 - 972418000
Dirección:	Plaça Sant Domènec, 3 Edifici Les Aligues 17071. Girona
Páginas	110



Resumen ejecutivo

Este documento presenta los resultados de las tareas del **Bloque 2 - Guía de aplicación de metodología de ciberdiagnóstico para la detección de ciberincidentes en el sector agua**, desarrollado en el marco del proyecto de **Apoyo ejecución acciones Cátedra INCIBE de Digitalización y Ciberseguridad Hídrica**.

El objetivo principal de este proyecto es la investigación y el desarrollo de una **metodología de autodiagnóstico de ciberseguridad** diseñada específicamente para PYMES del sector agua, en particular aquellas que forman parte de la cadena de suministro de agua potable y/o vinculables a dicho sector de actividad (**Tarea 2.1: Investigación y desarrollo de la metodología**).

La metodología, representa el marco teórico aplicable por PYMES sin experiencia previa en ciberseguridad, y se basa en los estándares y normas reconocidas como **NIST CSF**, **NIST 800-82**, **IEC62443**, y la herramienta de ciberseguridad de **AWWA**, así como en las recomendaciones del Centro de Ciberseguridad Industrial, y las obligaciones de la Directiva **NIS2**.

El proceso se estructura en cinco fases: **Ámbito** (definición de objetivo y alcance); **Preparación** (recopilación de documentación clave y organización del equipo); **Evaluación** (núcleo de la metodología basado en 90 controles); **Plan de acción** (priorización de medidas correctivas); **Informe** (presentación de los hallazgos).

Los controles, seleccionados por su relevancia y facilidad de implementación, se agrupan en seis áreas clave: gobernanza, seguridad de la red, control de acceso, protección de la información, seguridad física, formación.

Su selección se basa en el marco NIST 800-53 y el AWWA Cybersecurity Tool, y validada mediante un taller organizado por el **Catalan Water Partnership** y a través de entrevistas con expertos y profesionales del sector.

La metodología se ha diseñado teniendo en cuenta la realidad operativa de las PYMES del sector, simplificando la aplicación de funciones del NIST CSF y adaptando las áreas del NIST 800-82 para facilitar su adopción en entornos con recursos limitados, concentrando los controles en 6 grandes áreas: **gobernanza, seguridad de la red, control de acceso, protección de la información, seguridad física, formación**.

El informe también recoge la **Tarea 2.2: Estudio de 3 casos de éxito**, desarrollados por Eurecat, que abordan la ciberseguridad en diferentes contextos dentro del sector. Estos casos se recogen en el apartado **4 Casos de estudio** y ofrecen ejemplos prácticos y lecciones aprendidas que pueden servir de referencia para las PYMES interesadas en adoptar la metodología propuesta. Los casos analizan niveles de madurez distintos, describen vulnerabilidades y el impacto potencial en la salud pública y en sistemas de control. Se demuestra que la aplicación del autodiagnóstico hubiera reforzado significativamente la ciberseguridad, y se vinculan las mejoras potenciales con controles específicos de la metodología y finaliza con lecciones aprendidas.

En la ***Tarea 2.3: Propuesta de guía de aplicación***, como resultado de la ***Tarea 2.1: Investigación y desarrollo de la metodología***, se ha elaborado una guía práctica que describe la metodología con los pasos necesarios para su implementación. Esta guía incluye una herramienta en formato Excel que facilita su aplicación práctica en entornos reales, permitiendo a las PYMES llevar a cabo su propio proceso de diagnóstico.

Finalmente, el documento incluye un ***Breve estado del arte de la ciberseguridad en el sector agua***, que analiza las amenazas y ataques más relevantes a nivel global y revisa marcos normativos y metodologías de referencia. Los anexos aportan guías prácticas para la aplicación de algunos de los controles propuestos, como la elaboración de inventario o la segmentación de red.

Índice

RESUMEN EJECUTIVO	3
1. INTRODUCCIÓN	11
1.1. OBJETIVO DEL DOCUMENTO	11
1.2. ALCANCE DEL DOCUMENTO.....	13
1.3. ESTRUCTURA DEL DOCUMENTO	14
1.4. CRITERIOS PARA LA REALIZACIÓN DEL DOCUMENTO.....	15
2. BREVE ESTADO DEL ARTE DE LA CIBERSEGURIDAD EN EL SECTOR AGUA	16
3. METODOLOGÍA PARA EL DIAGNÓSTICO DE CIBERSEGURIDAD DEL SECTOR AGUA.....	27
3.1. PROPÓSITO DE LA METODOLOGÍA.....	27
3.2. DESARROLLO DE LA METODOLOGÍA.....	28
3.2.1 Marcos de referencias utilizados	28
3.2.2 Consideraciones normativas: la NIS2 y las PYMES del sector agua	29
3.2.3 Aportaciones del sector: talleres Catalan Water Partnership	30
3.2.4 Características del sector agua y enfoque adoptado	30
3.3. ESTRUCTURA DE LA METODOLOGÍA Y HERRAMIENTA EXCEL.....	32
3.4. FASES DE LA METODOLOGÍA.....	35
Ámbito.....	35
Preparación	38
Evaluación.....	40
Plan de acción.....	83
Informe	87
4. CASOS DE ESTUDIO.....	89
4.1. CASO DE ESTUDIO 1 - EMPRESA DE GESTIÓN INTEGRAL DEL CICLO DE AGUA	89
4.2. CASO DE ESTUDIO 2 - EMPRESA DE TRATAMIENTO DE AGUA	92
4.3. CASO DE ESTUDIO 3 - EMPRESA DE DISTRIBUCIÓN DE AGUA	94
5. CONCLUSIONES	96
6. FIRMAS	97
7. BIBLIOGRAFÍA.....	98
ANEXO I - INVENTARIO Y PLANTILLA DE INVENTARIO.....	101
Inventario	101
Plantilla Inventario (ejemplo).....	104
ANEXO II - PLAN DE RESPUESTA A INCIDENTES Y PLANTILLA	105
Plan de respuesta a incidentes	105
ANEXO III - ARQUITECTURA DE RED SEGURA: SEGMENTACIÓN Y MICROSEGMENTACIÓN DE RED	106
ANEXO IV - MARCOS, ESTÁNDARES Y GUÍAS DE REFERENCIA PARA LA CIBERSEGURIDAD EN EL SECTOR AGUA	108
8. CONTROL DE CAMBIOS.....	110

Índice de las tablas

Tabla 1. Incidentes en las infraestructuras de agua[28].....	26
Tabla 2. Ejemplo de ejecución de la fase Ámbito	37
Tabla 3. Ejemplo de ejecución de la fase de Preparación	40
Tabla 4. Ejemplo estructura de los campos que documentan los controles.....	41
Tabla 5. Guía de niveles de madurez para la evaluación de controles.....	42
Tabla 6. Ejemplo ejecución de la fase de Evaluación.....	44
Tabla 7. Datos inventario	102

Índice de las ilustraciones

Ilustración 1. NIST Cybersecurity Framework[19]	28
Ilustración 2. Estructura de la Metodología	33
Ilustración 3. Página inicial de la herramienta excel	33
Ilustración 4. Ejemplo fase Ámbito	36
Ilustración 5. Ejemplo de cómo rellenar el formulario de la fase de Preparación	39
Ilustración 6. Ejemplo práctico de aplicación de Evaluación	42
Ilustración 7. Indicadores de Evaluación Inicial	44
Ilustración 8. Ejemplo Plan de acción	84
Ilustración 9. Dashboard de la situación actual que muestra los avances del plan de acción	85
Ilustración 10. Ejemplo de Informe auto generado	88
Ilustración 11. Ejemplo de datos generales de inventario	103
Ilustración 12. Ejemplo arquitectura segura [43]	107

Glosario de términos

<i>APT (Advanced Persistent Threat)</i>	Es un conjunto de procesos informáticos sigilosos orquestados por un tercero con la intención y la capacidad de atacar de forma avanzada y continuada en el tiempo, un objetivo determinado
<i>Backup:</i>	Copia de seguridad de datos que permite restaurar la información en caso de pérdida o fallo del sistema
<i>CISA (Cybersecurity and Infrastructure Security Agency):</i>	Agencia de Seguridad de EEUU responsable de proteger infraestructuras en todos los niveles del gobierno
<i>Control:</i>	Medida implementada para reducir riesgos de ciberseguridad o proteger activos de información
<i>Controles compensatorios:</i>	Medidas alternativas que mitigan riesgos cuando no se pueden aplicar controles primarios
<i>Control de acceso:</i>	Restricción de acceso a sistemas o información únicamente a usuarios autorizados
<i>DLP (Data Loss Prevention):</i>	Tecnología que detecta o previene fugas o exfiltración de datos sensibles
<i>DMZ (Demilitarized Zone):</i>	Segmento de red aislado que separa los sistemas internos de los accesos externos
<i>Encriptación:</i>	Proceso de cifrar datos para que solo usuarios autorizados puedan acceder a su contenido
<i>ENS:</i>	Esquema Nacional de Seguridad España
<i>HMI (Human-Machine Interface):</i>	Interfaz que permite a los operadores interactuar con sistemas de control industrial
<i>ISA (International Society of Automation):</i>	Organización que desarrolla estándares para la automatización industrial
<i>IEC (International Electrotechnical Commission):</i>	Organización que elabora normas internacionales para tecnologías eléctricas y electrónicas
<i>Inventario:</i>	Registro actualizado de activos físicos y digitales de una organización
<i>KEV Catalog:</i>	Catálogo de vulnerabilidades explotadas conocidas, mantenido por CISA
<i>Log:</i>	Registro de eventos en sistemas informáticos
<i>MFA (Multi-Factor Authentication):</i>	Método de autenticación que requiere múltiples factores para verificar la identidad de un usuario
<i>Mitre Attack:</i>	Base de datos de tácticas, técnicas y procedimientos usados por actores maliciosos.

<i>NIS2 (Network and Information Security):</i>	Directiva europea sobre seguridad de redes y sistemas de información
<i>NIST (National Institute of Standards and Technology):</i>	Instituto Nacional de Estándares y Tecnología de EE. UU., que desarrolla marcos de ciberseguridad
<i>NIST CSF:</i>	Marco de Ciberseguridad del NIST, guía para mejorar la gestión del riesgo cibernético
<i>NVD database:</i>	Base de datos de vulnerabilidades publicada por el NIST, utilizada para seguimiento de amenazas
<i>Plan de respuesta a incidentes:</i>	Conjunto de acciones definidas para gestionar y mitigar los efectos de un incidente de seguridad
<i>RDP (Remote Desktop Protocol):</i>	Protocolo que permite acceder a un ordenador de forma remota a través de red.
<i>SIEM (Security Information and Event Management):</i>	Herramienta que recoge, analiza y correlaciona eventos de seguridad en tiempo real
<i>Segmentación de red:</i>	Separación de una red en subredes más pequeñas para limitar el movimiento lateral de amenazas
<i>Tabletop Exercise:</i>	Simulación de incidentes realizada en formato de discusión para evaluar planes y respuestas
<i>TTPs (Tactics, Techniques, and Procedures):</i>	Formas específicas en las que los atacantes operan para comprometer sistemas
<i>VPN (Virtual Private Network):</i>	Red privada virtual que cifra el tráfico entre el usuario y la red corporativa
<i>Vulnerabilidad:</i>	Debilidad en un sistema que puede ser explotada para comprometer su seguridad

1. Introducción

1.1. Objetivo del documento

El objetivo de este documento es presentar los resultados de las tareas del **Bloque 2 - Guía de aplicación de metodología de ciberdiagnóstico para la detección de ciberincidentes en el sector del agua**, desarrollado para el proyecto de **Apoyo ejecución acciones Cátedra INCIBE de Digitalización y Ciberseguridad Hídrica**.

Este bloque comprende cuatro tareas, de las cuales tres se presentan en este documento:

- **Tarea 2.1: Investigación y desarrollo de la metodología**, En esta tarea, se seleccionarán y definirán los pasos a seguir para desarrollar una metodología que permita el ciberdiagnóstico a las empresas del sector del agua. A partir de casos de estudio previos de Eurecat dónde ya se han implementado proyectos de diagnosis e implementación de mejoras de ciberseguridad, se identificarán los pasos a desarrollar por nuevas empresas que quieran mejorar su ciberseguridad a nivel de infraestructura, operacional y/o de sus equipos y dispositivos.
- **Tarea 2.2: Estudio de 3 casos de éxito**, Se documentarán 3 casos de éxito relevantes para el sector del agua, ya desarrollados por Eurecat. Al menos un caso abordará la ciberseguridad a nivel global de una organización dentro del sector del agua, mientras que otro se centrará en un dispositivo o programa específico. Estos estudios de caso proporcionarán ejemplos prácticos y lecciones aprendidas que pueden ser aplicadas para mejorar la ciberresiliencia en el sector.
- **Tarea 2.3: Propuesta de guía de aplicación**, En base a la investigación realizada en la tarea 2.1, Eurecat elaborará una guía de aplicación que describirá detalladamente la metodología para que pueda ser usada por nuevas empresas que quieran implementar medidas de ciberseguridad. La guía incluirá un breve estado del arte, los pasos a seguir para las empresas, así como ejemplos prácticos. Además, se incluirá los 3 casos de éxito desarrollados en la tarea 2.2.

En base a esto, este documento incluye:

- **La metodología de ciber diagnóstico (apartado 0**

- *Metodología para el diagnóstico de ciberseguridad del sector agua*), como modelo teórico que ayuda a entender las varias fases de un auto diagnóstico de ciberseguridad, pensada para ser usada por personales de PYMES del sector agua, en especial aquellas que forman parte de la cadena de suministro de agua potable y/o vinculadas a dicho sector de actividad. La metodología se compone por cinco fases y se basa en controles fundamentales agrupados en seis áreas clave.
- ***Tres estudios de caso reales*** (apartado 0

- *Casos de estudio*), desarrollados por Eurecat que sirven como ejemplos prácticos de aplicación.
- **La guía de aplicación** (una herramienta en formato Excel) que facilita el proceso de autoevaluación, el cálculo del nivel de riesgo (a través una práctica dashboard), la generación automática de plan de acción e informes.

El documento también incluye **un estado del arte** de amenazas y vulnerabilidades (*apartado 0*

Breve estado del arte de la ciberseguridad en el sector agua) comunes del sector agua y anexos complementarios con plantillas y recursos útiles para la aplicación de la metodología.

1.2. Alcance del documento

Este documento proporciona una metodología accesible para llevar a cabo un primer diagnóstico de ciberseguridad en infraestructuras de agua, que puede ser realizado por parte de los propietarios o de los empleados de dichas infraestructuras.

Está orientado a PYMES que operan sistemas de captación, tratamiento, distribución o gestión de agua potable y aguas residuales.

La metodología está dirigida al personal interno de las infraestructuras, para poder conocer el estado de la ciberseguridad y no requiere necesariamente la intervención de consultores externos. No obstante, para su correcta aplicación se recomienda a los lectores tener conocimientos previos de la infraestructura y conocimientos sobre conceptos generales de seguridad informática, TIC y protocolos de comunicación.

El público destinatario incluye los propietarios de las instalaciones, los ingenieros de control, los administradores de sistemas, profesionales de TI, responsables de la gestión de sistemas OT, los proveedores que desarrollan productos destinados a ser implementados como parte de un sistema OT.

La metodología no sustituye una auditoría de ciberseguridad, pero constituye una base sólida para entender el estado actual de la ciberseguridad, identificar debilidades que puedan ser explotadas por atacantes maliciosos y priorizar acciones correctivas para mejorar la seguridad de la infraestructura.

1.3. Estructura del documento

El resto del documento se divide en las siguientes secciones principales:

- **Sección 2** -

- **Breve estado del arte de la ciberseguridad en el sector** agua: en esta sección se presenta una revisión de amenazas y vulnerabilidades específicos del sector, y también una síntesis de marcos normativos, estándares y metodologías existentes
- **Sección 3 –**

- **Metodología para el diagnóstico de ciberseguridad del sector** agua: en esta sección se introduce la metodología propuesta. Se describen el enfoque y sus fases
- **Sección 4 –**

- **Casos de estudio:** en esta sección se presentan tres casos reales, que ilustran como se ha llevado a cabo un ciber diagnóstico de seguridad utilizando un enfoque metodológico como el presentado en este documento, así como las lecciones aprendidas durante las evaluaciones
- **Sección 5 – Conclusiones:** se presentan las conclusiones del informe

Además, esta guía contiene los siguientes Anexos con material complementario:

-

- **Anexo I – Inventario y plantilla de inventario**
- **Anexo II – Plan de respuesta a incidentes y plantilla**
- **Anexo III – Arquitectura de red segura: segmentación y microsegmentación**
- **Anexo IV – Marcos, estándares y guías de referencia para la ciberseguridad en el sector agua**

1.4. Criterios para la realización del documento

Para realizar el siguiente documento se han adoptado los principios metodológicos del PRISMA-Statement.

Los pasos realizados son los siguientes:

- **Definición del objetivo:** se estableció como propósito principal el diseño de una herramienta útil, repetible y adaptada a las necesidades específicas de PYMES del sector agua
- **Revisión de la literatura y estándares:** se analizaron documentos técnicos, marcos y estándares reconocidos en ciberseguridad industrial (IEC 62443, NIST CSF, CISA, entre otros) seleccionando los controles más pertinentes al entorno de operación de sistemas de agua
- **Incorporación de fuentes complementarias:** se incorporaron conocimientos extraídos de anteriores trabajos de diagnósticos de ciberseguridad realizados por Eurecat para las infraestructuras del sector, así como conocimientos derivados de entrevistas con profesionales del sector y estudios de casos reales
- **Revisión de casos de estudio:** estudio de vulnerabilidades y ciber incidentes en las infraestructuras de agua
- **Clasificación de la información:** la información recopilada se clasificó en categorías (Gobernanza, Seguridad de la Red, Control de Acceso, Protección de la Información, Seguridad Física, Formación)
- **Desarrollo de la metodología:** se diseñó una estructura clara de fases de diagnóstico (Ámbito, Preparación, Evaluación, Informe, Plan de Acción), alineada con los controles seleccionados
- **Desarrollo de la herramienta Excel:** simultáneamente se llevó a cabo la realización de una herramienta en Excel que permite tener un seguimiento de las varias fases y una aplicación práctica de los controles

2. Breve estado del arte de la ciberseguridad en el sector agua

Originalmente, los sistemas OT eran sistemas aislados que utilizaban protocolos propietarios y dependían de hardware y software especializados. Sin embargo, en los últimos años, todos los sectores industriales están viviendo una creciente digitalización que los lleva a integrarse con soluciones TI y estar cada vez más conectados a redes [1].

El sector del agua, tanto en sistemas de tratamientos de agua potables como de aguas residuales, no es ajeno a esta transformación. Actualmente, estas infraestructuras emplean hardware estándar, sistemas operativos comunes y protocolos de red abiertos, adoptando soluciones TI como el acceso remoto, la automatización, la supervisión en tiempo real y la gestión de recursos hídricos mediante plataformas digitales.

Esta convergencia IT/OT y las mejoras tecnológicas orientadas a optimizar la gestión del ciclo integral del agua (automatización, digitalización, monitorización remota, reutilización) han introducido nuevos vectores de ataque que pueden ser explotados por atacantes maliciosos, ampliando la superficie de ataques, y generando riesgos reales para la vida humana, afectando calidad del agua, la operación y la seguridad pública, el medio ambiente y la economía nacional.

A diferencia de los sistemas IT (donde se prioriza la confidencialidad de la información), los objetivos de seguridad en OT se centran en la disponibilidad y en la integridad, dejando la confidencialidad de los datos en un objetivo que requiere menos importancia. Además, la seguridad física (safety) entra como prioridad transversal [2]. Esto significa que la pérdida de disponibilidad puede generar consecuencias operativas graves y poner en riesgo la vida humana.

En este contexto, entre las amenazas más comunes en el sector se encuentran: el robo de información, ransomware, interrupción de suministro, manipulación de los procesos de tratamiento, acceso no autorizado, phishing, estafas, entre otros [2] [3], mientras las de mayor impacto son la afectación a la composición o al suministro del agua [3]. Por lo tanto, es esencial implementar medidas de ciberseguridad que permiten mitigar estos problemas: hablamos de segmentación de redes, MFA, detección de intrusiones, monitorización y formación continua del personal [2].

El sector agua incluye diversas empresas de la cadena de suministro de agua potable y servicios vinculados. La mayoría son PYMES que desempeñan un papel fundamental en el sector agua en Europa.

Estas empresas se dedican a actividades como captación y potabilización (estaciones de bombeo, plantas de tratamiento); distribución (urbanas y rurales); tratamiento y depuración de aguas residuales (gestión de lodos y subproductos); mantenimiento de infraestructuras (plantas potabilizadoras y depuradoras); provisión de servicios subcontratados para empresas concesionarias (monitorización, mantenimiento, análisis de calidad; fabricación o integración de soluciones tecnológicas (sensores, controladores, software SCADA, etc) [4] [5] [6].

Otra pymes relacionada, que forman parte del ecosistema, que pero no entran en el alcance de esta metodología son las firmas de ingeniería civil que diseñan y construyen infraestructuras (presas, acueductos, estaciones de tratamiento), productores de bombas, válvulas, tuberías, membranas y sensores para calidad del agua, suministradores de reactivos y materiales filtrantes para potabilización, empresas de servicios (laboratorios de análisis) que monitorizan la calidad del agua y ayudan a cumplir normativa; empresas que ofrecen servicios de telemetría, contadores inteligentes y software de gestión hidráulica [4].

Desde el punto de vista de la ciberseguridad, la mayoría de estas pymes no cuentan con recursos suficientes ni con personal especializado para afrontar los crecientes problemas de las amenazas cibernéticas [3] [7].

Como describe **Enisa** en su informe [7] la madurez cibernética del sector agua varía según la región, el tamaño de la empresa y su rol en la cadena de valor. Muchas Pymes del sector carecen de políticas de seguridad, controles de acceso, segmentación de redes, y formación del personal.

Es frecuente encontrar que las instalaciones carecen de ciberseguridad y tienen vulnerabilidades críticas, como el uso de contraseñas por defecto o sistemas de autenticación que pueden ser fácilmente comprometidos [8].

Estas debilidades exponen las pymes a amenazas como ransomware, sabotaje, cryptojacking, ataques internos [9] que pueden derivar en parálisis operativa, contaminación del suministro, daños a equipos e infraestructuras, pérdidas de datos, filtración de información, sanciones regulatorias, daño reputacional, e interrupción de contratos [9], [10].

Casos reales han evidenciado estas amenazas. Por ejemplos, se han demostrado incidentes donde atacantes accedieron a sistemas informáticos obsoletos, tomaron el control de válvulas y operaciones de flujo de agua y manipularon tanto el caudal como la cantidad de químicos utilizados en el tratamiento del agua. Asimismo, los atacantes han obtenido datos de clientes a través del sistema de pagos en línea de la empresa, consiguiendo credenciales de administrador y desplazándose lateralmente dentro de la red de agua [1].

Los efectos de un ataque cibernético sobre operaciones críticas del sector del agua podrían causar daños devastadores a la salud y seguridad pública: desde la introducción de protozoos, bacterias y productos químicos tóxicos en las redes comunitarias, hasta la interrupción de servicios críticos, dañar la infraestructura mediante sabotaje o vandalismo. Incluso los incidentes no intencionados (fallos de configuración, cortes eléctricos) pueden provocar la liberación de contaminantes, romper tuberías en áreas extensas o generar fallos en cascada en infraestructuras interconectadas (como cuando el daño en una red eléctrica afecta estaciones de bombeo y plantas de tratamiento), amenazar la seguridad nacional y dar lugar a costosos procesos de recuperación y remediación para abordar problemas del sistema, así como la pérdida de datos [11].

Los ciberataques a infraestructuras de agua ya son una realidad demostrada (*Tabla 1. Incidentes en las infraestructuras de agua*[28]).

Uno de los casos más destacados y conocidos es el incidente de la instalación Maroochy Shire[9] [12] [13], in Australia, una planta de recolección y tratamiento de aguas residuales. Se descubrió que el incidente fue causado por un contratista externo que accedió sin autorización al sistema SCADA y permitiéndole liberar aguas residuales sin tratar en el entorno circundante. La investigación reveló la falta de procedimientos y políticas de ciberseguridad, la falta de controles de acceso y medidas contractuales con servicios de terceros. Este incidente pudo haber tenido consecuencias más graves y habría sido prevenible mediante controles de gobernanza como los propuestos en esta metodología.

Otro caso relevante fue un incidente de criptojacking que afectó una empresa de agua europea [14] [15] [16]. La organización utilizaba un sistema de análisis OT basado en la nube para monitorizar su red. Se detectó la presencia de un malware de minería de criptomonedas en la red OT de la empresa de agua que causó un aumento del 60% en el consumo general de ancho de banda. Aunque el impacto operativo fue limitado, el incidente evidenció una falta de monitorización de la red y demostró como ataques silenciosos pueden comprometer recursos críticos. Con una activa monitorización de la red y mecanismos de detección de anomalías podría haber permitido una identificación temprana del ataque.

Frente a este contexto, la ciberseguridad se ha convertido en una prioridad clave para la industria del agua, por lo que tanto las entidades del sector como sus partes interesadas deben dedicar atención y recursos significativos para garantizar la preparación cibernética, desde una perspectiva tanto gubernamental como técnica. Una forma de abordar estos ataques es mediante la adopción de contramedidas, que permiten minimizar o prevenir los daños[1].

Algunas de las acciones recomendadas para proteger sistemas OT incluyen[17]:

- *La reducción de la exposición de los sistemas a internet*
- *Evaluaciones periódicas de seguridad*
- *Cambiar las contraseñas por defecto*
- *Tener un inventario actualizado de los activos IT y OT*
- *Tener un plan de respuesta a incidentes*
- *Redundancia de componentes críticos*
- *Separación lógica y física*
- *Gestión de control de accesos*
- *Gestión de contraseñas*
- *Antivirus, IDS, monitorización, uso de protocolos y servicios seguros*
- *Desactivación de puertos y servicios no necesarios*
- *Backup de los sistemas*
- *Formación del personal*

La aplicación de estas medidas son los primeros pasos para mejorar la postura de ciberseguridad de una infraestructura, logrando los objetivos principales de seguridad para un sistema OT que son restringir el acceso lógico y físico; proteger componentes de control; evitar modificaciones no autorizadas de datos; detectar eventos e incidentes de seguridad; mantener la funcionalidad ante condiciones adversas; recuperar la operatividad tras un incidente.

También es verdad que el sector del agua enfrenta desafíos en la implementación de estas contramedidas de seguridad, debido a la creciente interconexión de redes y sistemas, la multiplicidad de estándares de ciberseguridad entre distintos sectores, la gran diversidad de equipos industriales con tecnología propietaria, las diferencias entre los enfoques de los proveedores para cumplir con los estándares de seguridad, la dispersión geográfica de las infraestructuras, la necesidad constante de garantizar la calidad del servicio sin interrumpir la operación [18].

Estos desafíos pueden enfrentarse mediante la adopción voluntaria de estándares de seguridad apropiados, la realización de un análisis de brechas, la evaluación de vulnerabilidades y la implementación de contramedidas alineadas tanto con los requisitos de seguridad como con las necesidades del sector del agua [1].

En este contexto, la metodología propuesta en este documento busca responder a estos desafíos mediante un enfoque estructurado y adaptado a la realidad de las PYMES del sector. Su aplicación permite auto diagnosticar el estado de la ciberseguridad, identificar áreas críticas de mejora, priorizar medidas de mitigación y prevenir incidentes que puedan comprometer la operación.

La metodología propuesta en este documento se basa en marcos de referencia, estándares y guías reconocidos internacionalmente que permiten evaluar, planificar y fortalecer la postura de seguridad de las organizaciones. Todos estos marcos siguen el mismo principio: ofrecer controles, buenas prácticas y recomendaciones que permiten sistematizar la gestión del riesgo y establecer procesos sostenibles de mejora continua.

Estos marcos, guías, estándares tienen diferentes niveles de aplicación y evaluación: desde un autodiagnóstico básico hasta modelos avanzados de gestión y certificación. Aunque su adopción suele ser voluntaria, son fundamentales para demostrar cumplimiento con normativas cada vez más exigentes como la directiva NIS2, que impone responsabilidades específicas a las PYMES que operan en el sector agua.

La aplicación de estos marcos permite evaluar la postura de ciberseguridad de una organización, identificar vulnerabilidades y priorizar un plan de acción para implementar acciones de mejora. Sin embargo, muchas pequeñas empresas del sector agua no cuentan con departamentos de ciberseguridad que puedan enfrentarse al alto grado de tecnicismo o complejidad documental de estos marcos o para realizar pruebas técnicas para la evaluación de la situación actual de la planta. Por eso la metodología que se presenta en este documento propone una adaptación simplificada de estos marcos, diseñada específicamente para ser implementada por personal técnico u operativo y generar resultados útiles y accionables en poco tiempo.

Los principales marcos y estándares de referencia aplicables al sector agua son:

- *NIST Cybersecurity Framework* [19]
- *NIST SP 800-82, guía para la protección de tecnologías operacionales (OT) e infraestructuras críticas* [20]
- *IEC 62443, estándar internacional para sistemas de automatización y control industrial* [21]
- *Guía de la American Water Work Association (AWWA)* [22]
- *EPA Cybersecurity for the Water Sector* [23]
- *WaterISAC* [24]

En Europa, los sectores están sujetos a la Directiva NIS2, que impone requisitos obligatorios de ciberseguridad a los operadores esenciales, exigiendo medidas de prevención, detección y respuesta a incidente. Por otro lado, otras directivas sectoriales como la EU Drinking Water Directive [25] y la EU Urban Waste Water Treatment Directive [26] no contemplan cuestiones ligadas a la ciberseguridad[7].

Cabe destacar también la iniciativa del NIST y MITRE, que están realizando un proyecto junto para cubrir las necesidades de la ciberseguridad para las infraestructuras de agua potables y residuales [27]. El objetivo de este marco es identificar escenarios comunes de riesgos de ciberseguridad entre las empresas de servicios de agua y abordar varias áreas como la gestión de activos, la integridad de los datos, el acceso remoto y la segmentación de redes.

En definitiva, la alta complejidad técnica y documental de estos marcos, dificulta la adopción por parte de PYMES del sector agua, que a menudo carecen de recursos humanos y económicos suficientes.

La metodología presentada en este documento responde a esta necesidad mediante un enfoque simplificado y práctico, con un proceso guiado que permite realizar un autodiagnóstico sin necesidad de auditorías externas, identificar brechas importantes de seguridad, priorizar medidas correctivas y contribuir al cumplimiento progresivo de los requisitos de ciberseguridad establecidos por la NIS2. Este enfoque proporciona a las organizaciones un punto de partida claro desde el cual comprender su situación actual y definir objetivos de mejora realistas y alcanzar niveles fundamentales de ciberseguridad.

La tabla a continuación recoge diversos incidentes documentados en infraestructuras de agua en todo el mundo[28]:

Date	Attack Description	Country	Link at the Internet
08/11/2024	Ransomware attack on SABESP highlights the need for strengthened cybersecurity.	Brazil.	https://tisafe.com/ataque-ransomware-contra-a-sabesp-entenda-mais-sobre-os-impactos-da-invasao-de-hackers-a-companhia-e-as-principais-

			medidas-para-evitar-novas-ocurrencias/
18/11/2024	Report exposes critical cybersecurity flaws in drinking water systems, threatening services and data of millions of people.	United States	https://www.secureworld.io/industry-news/cybersecurity-leaks-usa-drinking-water-systems
09/10/2024	Hackers compromise American Water's billing system, highlighting vulnerabilities in critical infrastructure without affecting services.	United States	https://www.secureworld.io/industry-news/american-water-cyber-attack
22/09/2024	Cyberattack forces Arkansas City water treatment facility to switch to manual operations without impacting water supply.	United States	https://www.secureworld.io/industry-news/kansas-water-facility-cyber-incident
14/02/2024	Southern Water has warned that data belonging to 5-10% of its customers has been stolen in a cyberattack, including personal and financial information that may have been sold on the dark web.	United Kingdom	https://www.bbc.com/news/uk-england-kent-68284475
01/12/2023	Iranian hackers compromise PLCs at a U.S. water station, disrupting operations and forcing a switch to manual control.	United States	https://www.secureworld.io/industry-news/iranian-hackers-target-us-water-facility
27/11/2023	The Municipal Water Authority of Aliquippa in Pennsylvania has confirmed that hackers took control of a system of the substation	United States	https://www.securityweek.com/hackers-hijack-industrial-control-system-at-us-water-utility/
27/09/2023	The National Water and Basic Sanitation Agency (ANA) suffered a hacker attack on September 27, which rendered several of the agency's systems unavailable [1] Interruption of services and operation [2] Unauthorized Access a Networks [3] Unauthorized Acces	Brazil	https://www.convergenciadigital.com.br/Seguranca/Hackers-invadem-Agencia-Nacional-de-Aguas-e-pedem-resgate-em-bitcoins-64429.html
14/09/2023	The International Joint Commission (IJC), which manages water systems along the USA-Canada border, confirmed to have been the target of a cyberattack. [1] Interception of convenient	United States and Canada	https://www.scmagazine.com/brief/cyberattack-impacts-international-joint-commission

	Information [2] Violation of laws and regulation [3] Data exposure threat		
16/12/2022	Aegea suffers cyberattack	Brazil	https://istoe.com.br/aegea-sofre-ataque-cibernetico/
16/08/2022	Ransomware Group Claims Access to SCADA in Confusing UK Water Company Hack	United Kingdom	https://www.securityweek.com/ransomware-group-claims-access-scada-confusing-uk-water-company-hack
11/07/2022	Semae suffers cyberattack and services are impacted	Brazil	https://www.securityreport.com.br/destaques/sem-ae-sofre-ataque-cibernetico-em-sistemas/#.Ys1iqbfMKUk
07/03/2022	Clark County Water Reclamation District computer system hacked	United States	https://www.reviewjournal.com/local/local-las-vegas/clark-county-water-reclamation-district-computer-system-hacked/
04/01/2022	Ransomware at Mato Grosso do Sul water company	Brazil	https://www.cisoadvisor.com.br/ransomware-na-estatal-de-saneamento-de-mato-grosso-do-sul/
18/11/2021	Ohio health system forced to cancel appointments following 'targeted cyber attack'	United States	https://www.healthcareitnews.com/news/ohio-health-system-forced-cancel-appointments-following-targeted-cyber-attack-0
10/07/2021	Oldsmar water hack: what happened and why it could happen again	United States	https://www.baynews9.com/fl/tampa/news/2021/04/09/oldsmar-water-hack--what-happened-and-why-it-could-happen-again
20/02/2021	Multiple waterline breaks due to software malfunction in the City of Bloomington	United States	
05/02/2021	Oldsmar city water system has been breached	United States	
01/10/2020	Ransomware hit a major U.S. hospital and healthcare network	United States	https://www.securityreport.com.br/overview/ransomware-atingiu-uma-importante-rede-de-hospitais-e-servicos-de-saude-dos-eua/
06/06/2020	Lorien Health Services	United States	https://securityboulevard.com/2020/07/maryland-based-nursing-home-announces-ransomware-

			attack-affecting-nearly-50000-residents/
24/04/2020	Attempted violation of the plant system(s) at the Israeli Water Plant(s)	Israel	
24/04/2020	The 'synchronized and organized attack' on civilian infrastructure was aimed at disrupting the industrial computers that underpin Israeli	Israel	
06/02/2020	Rockdale County Water Resources	United States	https://www.ajc.com/news/local/rockdale-water-customers-can-make-payments-again-after-ransomware-attack/4GshKfGFW0w8yjCOh376SM/
01/02/2020	North Miami Beach Police Department	United States	https://www.cisomag.com/miami-beach-police-department-suffers-ransomware-attack/
02/12/2019	Medical Diagnostic Laboratories	United States	https://www.beckershospitalreview.com/cybersecurity/mdlabs-refuses-to-pay-1-7m-ransomware-demand-hackers-threaten-to-release-data.html
29/05/2019	Ransomware attack against the municipality of Riviera Beach	United States	
27/03/2019	Ellsworth County Rural Water District had its water system breached	United States	
11/02/2019	Fort Collins-Loveland Water District and the South For Collins Snaitation District, Colorado	United States	https://www.eenews.net/stories/1060131769
04/10/2018	Onslow County Water and Sewer	United States	https://www.securityweek.com/what-onslow-water-and-sewer-authority-can-teach-about-responsible-disclosure
25/04/2016	Ransomware - Lansing Board of Water & Light	United States	http://www.lansingstatejournal.com/story/news/local/2016/11/25/bwl-prepared-ransomware-attack/94332454/
07/03/2016	Ransomware - Clark County Water Reclamation	United States	https://www.reviewjournal.com/local/local-las-vegas/clark-county-water-reclamation-district-computer-system-hacked/

24/08/2015	Accidental sewage discharge due to operator error in the City of Honolulu	United States	
07/04/2014	California water line break due to software malfunction	United States	
05/01/2012	Computer Malfunction Blamed for Major Sewage Spill	United States	
03/01/2012	Wastewater Treatment District Hacked	United States	
14/11/2011	Water Utility Hack Destroys Pump	United States	https://www.theregister.com/2011/11/17/water_utility_hacked/
01/04/2011	Greenfield Wastewater Treatment Plant intentionally shut down critical systems	United States	
15/01/2011	South Houston Water Treatment Plant Hack	United States	
11/07/2010	Low Water Storage Due to Monitoring System Failure in the City of Lake Havasu	United States	
11/06/2010	The city of Lake Havasau, California, experienced a water shortage problem due to a SCADA system failure.	United States	
15/01/2010	Water plant shut down by computer glitch	United States	
10/01/2010	Computer Glitch Causes Water Outage	United States	
08/01/2010	SCADA Water System Fails	United States	
03/01/2010	Power Failure Leads to Sewage Spill in Washington	United States	
23/01/2009	Computer Glitch Causes Sewage Spill	United States	
22/01/2009	Faulty Water Level Alarm Cause of Sewage Spill	United States	
21/01/2009	Puget Sound Sewage Spill	United States	
15/01/2009	Computer Glitch Floods Neighborhood	United States	
14/01/2009	Lightning Strikes Cause Sewage Pump Station Overflow	United States	
13/01/2009	Flood Warning System Failure Causes Flooding	England	

12/01/2009	Computer Glitch Causes 7 Water Mains to Break	United States	https://www.nj.com/hudson/2009/07/seven_water_mains_break_in_jer.html
06/01/2009	Wastewater pumped into Jones Falls	United States	
02/01/2009	Faulty Software Causes Torrens Lake Drain	Australia	
07/01/2008	Hacker Disabled Offshore Oil Platforms	United States	
23/04/2007	Operator Error / Configuration Error at the water treatment plant in the City of Spencer	United States	
08/01/2007	Switch Malfunction Causes Sewage Spill	United States	
07/01/2007	California Canal System Hack	United States	
05/01/2007	Sewage Spill Shuts Down a Cornish Shellfishery	England	
04/01/2007	Computer Glitch Causes Overflowing Water Tower	United States	
01/01/2007	SCADA Communications Problems Cause Breakdown in Water Supply	United States	
09/01/2006	Pennsylvania Water Company Hack	United States	
23/03/2005	BP Texas City Refinery suffered one of the worst industrial disasters in recent U.S. history.	United States	
08/01/2005	Attempted Cover-Up of Sewage Spillage	Australia	
02/01/2005	Routine Audit of SCADA Laptop Identifies Virus	Australia	
20/01/2004	Trojan Backdoor on Water SCADA System	Canada	
26/02/2003	Proposed Hack of UK Water Systems	England	
25/02/2003	MUMU Infection of Fiscal Metering System	England	
23/02/2003	Baseline Audit Uncover Virus in Water Control System	Australia	
05/01/2003	Contractor Accidentally Connects to Remote PLC	United States	
08/01/2002	Penetration Test Locks-Up Gas Utility SCADA System	United States	
04/01/2002	IP Address Change Shuts Down Chemical Plant	United States	

02/01/2000	Maroochy Shire Sewage Spill [1] Adulteration or alteration in architecture of physical devices and of software [2] Violation of laws and regulation	Australia	
------------	--	-----------	--

Tabla 1. Incidentes en las infraestructuras de agua[28]

3. Metodología para el diagnóstico de ciberseguridad del sector agua

En este apartado se presenta la metodología de diagnóstico de ciberseguridad del sector agua.

3.1. Propósito de la metodología

La metodología ha sido elaborada con el propósito de apoyar a los operadores o a los propietarios de PYMES del sector agua, en especial aquellas que forman parte de la cadena de suministro de agua potable y/o vinculadas a dicho sector de actividad.

Su objetivo es proporcionar una herramienta accesible que permita

- evaluar el estado actual de la ciberseguridad en sus infraestructuras
- identificar y priorizar vulnerabilidades que pueden afectar la continuidad del servicio, la salud pública y la seguridad física
- adoptar medidas básicas de protección sin necesidad de recursos tecnológicos o humanos especializados.

En general, las PYMES del sector agua suelen tener baja visibilidad, infraestructuras obsoletas y poca concienciación en ciberseguridad [3], lo que las convierte en objetivos vulnerables. Esta metodología pretende responder a esta realidad fomentando la adopción de buenas prácticas de ciberseguridad mediante un proceso de auto diagnóstico, y facilitando la preparación al cumplimiento de normativas como por ejemplo la NIS2.

La metodología no sustituye a una auditoría formal ni garantiza el cumplimiento normativo, pero permite sentar una base sólida para tener una visión general de la ciberseguridad de la organización y mejorar en aspectos que pueden representar riesgos importantes.

3.2. Desarrollo de la metodología

El desarrollo de la metodología ha implicado diversas actividades de investigación que han permitido seleccionar y definir los pasos necesarios para desarrollar una metodología de auto diagnóstico aplicable a las empresas del sector del agua.

El proceso incluyó un análisis de marcos normativos y técnicos existentes y de las características y de las tecnologías del sector.

Además, en el marco del proyecto se participó a talleres de ciberseguridad que han permitido confrontarse con expertos del sector y que ha permitido destacar la realidad de las PYMES, así como los problemas que enfrentan en materia de ciberseguridad.

3.2.1 Marcos de referencias utilizados

Esta metodología ha sido desarrollada tomando como referencia principal el NIST CSF 2.0 [19], adaptándolo al contexto del sector agua tomando en cuenta las características y limitaciones de las PYMES del sector agua.

El NIST CSF 2.0 proporciona una estructura basada en seis funciones que permite evaluar el nivel de madurez en ciberseguridad y priorizar acciones de mejoras.

Las seis funciones del NIST CSF 2.0 son:

- **Governance:** la estrategia, roles y políticas de gestión de riesgos
- **Identify:** conocer los activos, procesos, roles, riesgos
- **Protect:** aplicar medidas preventivas para proteger activos e información
- **Detect:** establecer capacidades para detectar actividades anómalas
- **Respond:** contar con mecanismos para responder a incidentes
- **Recover:** definir planes para restaurar operaciones tras un incidente



Ilustración 1. NIST Cybersecurity Framework[19]

Además del NIST CSF, se han considerados otras referencias técnicas que han contribuido a la selección y definición de los controles y a garantizar que la metodología esté alineada con estándares y normativas internacionales de ciberseguridad reconocidos.

Estas referencias son:

- **NIST 800-82r3 Guide to Operational Technology Security** [29] , que proporciona directrices específicas para proteger el entorno OT
- **AWWA Cybersecurity Guidance** [22] desarrollado por la American Water Works Association (AWWA).
- **IEC 62443** [21] , que establece requisitos para la ciberseguridad en sistemas de control industrial
- La Guía de ciber diagnóstico del **Centro de Ciberseguridad Industrial (CCI)** [30].

3.2.2 Consideraciones normativas: la NIS2 y las PYMES del sector agua

Además de los marcos técnicos mencionados, esta metodología incorpora como referencia normativa la Directiva NIS2, debido a su impacto potencial en el sector del agua y en las PYMES que forman parte del entorno.

La NIS2 tiene como objetivo *“ampliar el ámbito de aplicación por sectores a una parte más extensa de la economía para ofrecer una cobertura completa de los sectores y servicios de vital importancia para las actividades sociales y económicas fundamentales dentro del mercado interior”*. La Directiva incluye específicamente los servicios de **agua potable** (suministradores y distribuidores de aguas destinadas al consumo humano, con exclusión de aquellas en las que dicha distribución no represente una parte esencial de su actividad) y **aguas residuales** (entidades que recogen, eliminan o tratan aguas residuales urbanas, domésticas o industriales, excluyendo también aquellas en las que esta actividad no sea esencial).

Además, clasifica las entidades en [31]:

- **Esenciales:** organizaciones que ocupan al menos 250 empleados o superan los 50 millones de euros en volumen anual de negocios o 43 millones en balance general, o que cumplen criterios estratégicos definidos por los Estados miembros
- **Importantes:** organizaciones con al menos 50 empleados o más de 10 millones de euros de facturación anual, así como otras entidades identificadas por los Estados miembros por su impacto potencial

Aunque muchas PYMES no alcanzan estos umbrales, pueden verse afectadas de forma indirecta por su participación en la cadena de suministro de entidades obligadas a cumplir con la Directiva.

Esto implica que se le puede exigir el cumplimiento de ciertas medidas de ciberseguridad para garantizar la seguridad de todo el sistema.

Como consecuencia, las PYMES que forman parte de la cadena de suministro de agua potable y tratamiento de aguas residuales deben reforzar aspectos como **la seguridad física** y perimetral de sus infraestructuras; **la protección de sistemas SCADA** mediante segmentación de red, aislamiento, cifrado de comunicaciones, autenticación fuerte, control de acceso RBAC, privilegio mínimo, actualización de software, revisión de permiso; **la monitorización continua** y la detección de amenazas; **la gestión de vulnerabilidades**; **la respuesta ante incidentes** con planes de contingencia, copias de seguridad, simulacros[31]. Por este motivo la metodología alinea sus controles con los requerimientos generales de la NIS2.

3.2.3 Aportaciones del sector: talleres Catalan Water Partnership

Durante el desarrollo de esta metodología, se han recogido las contribuciones de expertos y representantes del sector, a través de talleres organizados por el **Catalan Water Partnership** [32] [3] [33] [34] [35].

En estos talleres participaron expertos de ciberseguridad, responsables de operaciones, proveedores de servicios, representantes de entidades vinculadas al sector agua, que han puesto el foco en la realidad operativa de las PYMES del sector y han evidenciado aspectos importantes, donde destacan:

- El usuario que sigue siendo el principal vector de ataque, lo que subraya la necesidad de invertir en formación y concienciación
- Los ataques más críticos son aquellos que comprometen el suministro o la calidad del agua
- El entorno OT sigue siendo el más desprotegido
- Existe una falta estructural de inversión en ciberseguridad

Estas contribuciones también han sido importantes para desarrollar y orientar la metodología.

3.2.4 Características del sector agua y enfoque adoptado

Para diseñar una metodología adaptada a la realidad de las PYMES del sector agua, también se ha llevado a cabo un análisis de sus funciones, su infraestructura tecnológica y los factores que las exponen a riesgos de ciberseguridad.

Generalmente, estas organizaciones pueden agruparse en tres grandes bloques: **producción, tratamiento y distribución de agua; supervisión y control de procesos industriales y gestión administrativa y regulatoria**.

Todas estas funciones están altamente digitalizadas y conectadas y las convierten en puntos vulnerables desde el punto de vista de la ciberseguridad.

Mientras que el análisis ha evidenciado que entre las tecnologías más comunes se encuentran: **infraestructuras OT** (PLC, SCADA, RTU, sensores, etc.), **infraestructuras IT** (workstations, servidores, impresoras, ERP), **acceso remoto, soluciones en la nube** (historiales, backup de datos).

A pesar de esta creciente digitalización, muchas de estas organizaciones no disponen de departamentos de ciberseguridad, ni de personal técnico capacitado. Además, se señala una falta de recursos económicos que limita la implementación de medidas de ciberseguridad en la organización[3], [34], [35].

3.3. Estructura de la metodología y herramienta Excel

A partir del análisis realizado, el estudio de los marcos normativos y técnicos (NIST CSF, NIST SP 800-82, IEC 62443), la experiencia de Eurecat en diagnósticos de ciberseguridad y las aportaciones recogidas durante los talleres, se ha definido una **metodología** estructurada en fases, concebida para guiar a las PYMES en un proceso de auto diagnóstico.

Desde el punto de vista metodológico, se adopta un enfoque por fases, que facilita el seguimiento paso a paso. Mientras, desde el punto de vista de una guía de aplicación práctica (tal como se pide en la propuesta), se ha desarrollado una guía, incluida en este informe, acompañada de una herramienta en formato Excel que acompaña al usuario en cada fase, permitiendo registrar información, analizar resultados y generar automáticamente planes de acción e informes.

La metodología se organiza en cinco fases secuenciales que guían al evaluador de forma clara durante el proceso de auto diagnóstico, sin requerir conocimientos técnicos avanzados ni herramientas especializadas. Las cinco fases son:

- **Ámbito:** en esta fase se definen los activos, procesos y sistemas que serán objeto de evaluación (ej. El nombre y la ubicación de la instalación, tipo de planta, etc.)
- **Preparación:** en esta fase se establece el equipo evaluador, se analiza la estructura organizativa y se construye o revisa el inventario de activos, con el objetivo de tener un conocimiento preciso del entorno
- **Evaluación:** en esta fase se aplican los controles que están divididos en seis áreas para facilitar su seguimiento (*Gobernanza, Seguridad de la Red, Control de Acceso, Protección de la Información, Seguridad Física, Formación*). En esta fase se analiza el nivel de implementación de los controles, permitiendo identificar brechas y oportunidades de mejora.
- **Plan de Acción:** en esta fase se priorizan y definen las medidas correctivas a implementar para reducir las vulnerabilidades detectadas
- **Informe:** en esta fase se documentan los hallazgos

El núcleo central de la metodología es la fase de **Evaluación** que define un conjunto de 90 controles en las seis áreas que son una agrupación operativa adaptada a PYMES y su correspondencia con las seis funciones del NIST CSF se incluye en el Anexo.

La fase de Evaluación valora cada control según su nivel de implementación utilizando una escala de madurez de cinco niveles: **Inexistente, Parcial, Básico, Gestionado, Optimizado**.

Cada control está vinculado a recomendaciones prácticas que pueden consultarse directamente en esta guía en los subapartados de la fase de **Evaluación**. También en los anexos se proporcionan ejemplos de aplicación práctica de algunos de estos controles.



Ilustración 2. Estructura de la Metodología

Para facilitar la aplicación práctica de esta metodología, como se pedía en la propuesta del proyecto, se ha desarrollado una herramienta de soporte en formato Excel.

La herramienta permite:

- Guiar al usuario durante la ejecución de cada fase
- Registrar información y hallazgos de forma estructurada
- Generar automáticamente recomendaciones y planes de acción
- Generar informes
- Visualizar gráficamente el estado de los controles actuales y de las implementaciones

Diagnóstico de Ciberseguridad para Infraestructuras de Agua

Esta hoja de Excel es parte del kit de autodiagnóstico para evaluar la ciber resiliencia de PYMES del sector agua. Es una auto evaluación dirigida a los responsables de ciberseguridad, los propietarios de infraestructuras o a operadores que deseen evaluar el estado de la ciberseguridad de sus instalaciones. El objetivo es facilitar un diagnóstico inicial que permita identificar vulnerabilidades, priorizar mejoras y fortalecer la postura de ciberseguridad de la organización mediante un enfoque práctico alineado con el NIST CSF.

Importante: La herramienta no recopila ni almacena datos personales ni sensibles.

¿Cómo usar esta herramienta?
Sigue los siguientes pasos para completar el diagnóstico

Icono	Paso	Descripción
📋	Paso 1: Alcance	Define la instalación a evaluar. Indica ubicación, tipo y responsable
👥	Paso 2: Preparación	Organiza el equipo de evaluación y revisa la documentación disponible
✅	Paso 3: Evaluación	Evalúa cada control y selecciona su estado (Sí, No, Parcialmente, N/A)
📊	Paso 4: Dashboard	Visualiza el estado general y las áreas más críticas
🔧	Paso 5: Plan de Acción	Identifica controles no cumplidos y planifica acciones
📄	Paso 6: Informe	Genera el informe con resumen y hallazgos clave

Referencias

Fuente	Tipo	Enlace
NIST	Framework	https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf
AWWA	Guía	https://www.awwa.org/resource/cybersecurity-guidance

Ilustración 3. Página inicial de la herramienta excel

Sin embargo, es importante destacar que el uso de esta herramienta es opcional y que las PYMES son libres de utilizar la misma o adoptar herramientas propias, sistemas ya existentes o cualquier otro recurso que consideren adecuado. El objetivo es que se comprendan y se sigan las fases de la metodología, ya que cada una aporta elementos clave para realizar un auto diagnóstico de ciberseguridad coherente y alineado con las recomendaciones de los más importantes estándares de ciberseguridad.

La herramienta ayuda a realizar las fases propuestas en la metodología, y no sustituye la responsabilidad de la organización que debe garantizar la veracidad y objetividad en la autoevaluación. Asimismo, el uso de la herramienta no implica la realización de pruebas activas o intrusivas, preservando la integridad de los entornos operativos.

3.4. Fases de la metodología

En este apartado se presentan de forma estructurada las distintas fases que componen la metodología, describiendo para cada una de ellas su propósito, alcance y las acciones necesarias para su correcta ejecución.

Ámbito



El objetivo de esta fase es definir con precisión el alcance del ciberdiagnóstico: activos, procesos y localizaciones incluidos y excluidos, roles, así como el plan básico para ejecutar las siguientes fases. Esta fase es obligatoria y condiciona la calidad del resto del proceso.

Desde el punto de vista metodológico y operativo, en esta fase es importante delimitar que se evalúa, asignar roles y responsables, establecer supuestos, dependencias y restricciones.

La información mínima que debe recopilarse en esta fase es:

- **Nombre de la instalación:** sirve para identificar de forma única el sitio evaluado. Ejemplo: Estación de bombeo Manresa, Planta de tratamiento de Manlleu, etc.
- **Tipo de instalación:** sirve para comprender el rol operativo del sitio. Ejemplo: tratamiento, captación, estación de bombeo, laboratorio, etc.
- **Ubicación/dirección:** localización del sistema evaluado, que facilita la trazabilidad y organización del diagnóstico
- **Responsable del diagnóstico:** es la persona de contacto que coordinará las varias fases, necesaria para llevar a cabo el diagnóstico y facilitar su ejecución
- **Responsable de la instalación:** es la persona de contacto de la instalación/planta evaluada
- **Fecha de evaluación:** registra cuando se realizó el ciber diagnóstico en la instalación, permitiendo tener una trazabilidad
- **Número de empleados en sitio:** sirve para tener una idea del tamaño de la instalación y la complejidad del sistema
- **Procesos operativos presentes:** describir brevemente que funciones realiza la instalación. Ejemplo: tratamiento químico, monitoreo, control de válvulas
- **Normas aplicables:** cualquier marco normativo, reglamentario relevante para el sitio evaluado

- **Dependencias claves:** sistemas, infraestructuras o proveedores externos que condicionan el funcionamiento de la instalación
- **Sistemas fuera de alcance:** áreas, sistemas o procesos que se excluyen del alcance del diagnóstico

Es importante destacar que estos son los datos mínimos recomendados, cada organización puede complementar esta información con detalles adicionales relevante para su contexto operativo.

Para facilitar la aplicación práctica de la fase de Ámbito, la herramienta asociada proporciona un formulario que permite recopilar de manera ordenada toda la información necesaria e integrar esta información en el informe final que genera la misma herramienta.





Diagnóstico de Ciberseguridad para Infraestructuras de Agua

Ámbito
 El objetivo de esta fase es establecer qué parte de la infraestructura será objeto del ciber diagnóstico

Identificación	
Nombre de la instalación	Instalación Agua
Tipo	Estación de bombeo
Dirección	carrer Bilbao

Responsabilidades	
Responsable del diagnóstico	Lopez Garcia
email/telefono	60000000
Responsable de instalación	Sanchez
email/telefono	60000000

Dimensión	
Nº empleados on-site	26
Caudal o población atendida	n/a

Procesos/Operaciones	
Descripción resumen	tratamiento agua

Entorno regulatorio

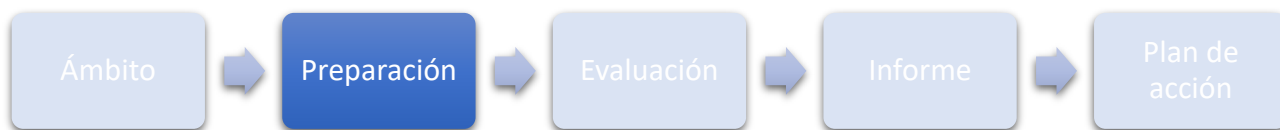
Ilustración 4. Ejemplo fase Ámbito

Un ejemplo práctico recomendado para la aplicación de esta fase, que puede ser llevado en un tiempo máximo de una hora, puede ser:

Reunión inicial	• <i>Explicar los objetivos y el alcance del diagnóstico</i> • <i>Confirmar fases, tiempos y roles asignados</i>
Rellenado del formulario Ámbito	• <i>El responsable del diagnóstico proporciona los datos en la herramienta Excel</i>
Revisión y validación	• <i>Confirmar los datos claves</i>

Tabla 2. Ejemplo de ejecución de la fase Ámbito

Preparación



El objetivo principal es obtener una comprensión clara de la organización, su estructura, sus procesos, sistemas, personas, roles, políticas, establecer y definir el equipo de trabajo que realizará el diagnóstico.

Tras la fase de **Ámbito**, donde se define la parte de la infraestructura (el alcance) que será objeto del ciber diagnóstico, la fase de **Preparación** es el segundo paso obligatorio dentro de la metodología de autoevaluación de ciberseguridad.

Su objetivo es recopilar y revisar la información disponible para comprender con precisión el entorno en el que se aplicará la metodología. Esta fase ayuda a organizar los recursos, equipos y documentación y adaptar el diagnóstico a la realidad operativa de la organización, teniendo en cuenta que muchas PYMES del sector agua presentan diferentes niveles de digitalización, recursos y madurez en ciberseguridad (por ejemplo, si solo hay un responsable de planta que también cubre mantenimiento y operación).

Desde un punto de vista metodológico, las actividades principales de esta fase son:

- **Planificación del trabajo**, donde se define el calendario de actividades y el cronograma de ejecución, se estiman los tiempos y los recursos necesarios y se establecen los canales de comunicación. Permite anticipar cuándo y cómo se harán las actividades clave (revisión de documentos y revisión técnica) evitando retrasos y malentendidos.
- **Definición del equipo de trabajo**, donde se identifican y asignan los roles que participarán en el proceso como responsables de ciberseguridad, personal de plantas, responsables de tecnología de la información, de tecnología operacional, mantenimiento y otras áreas relevantes. Asegura que todas las áreas clave están representadas e identifica claramente a los interlocutores durante el proceso. Ayuda a crear un equipo que facilite y colabore activamente durante el diagnóstico.
- **Revisión de la documentación existente**, donde se recopila y analiza la presencia o el estado de los diagramas de red OT e IT, las políticas de acceso, de contraseñas, los inventarios de activos, los planes de contingencia, los planes de respuesta a incidentes, los planes de continuidad operativa; los informes de incidentes o auditorías anteriores y los contratos y acuerdos con terceros. Permite saber qué información existe, qué falta y dónde buscar.

Esta fase no requiere que toda la documentación esté completa desde el inicio, ya que su ausencia será registrada como parte del diagnóstico inicial en la fase de **Evaluación**. La prioridad es recopilar la información para obtener una fotografía preliminar del entorno.

También, es importante anotar la existencia o ausencia de documentación, su ubicación, responsables, y observaciones relevantes para poder tener un seguimiento en futuras evaluaciones.

Se recomienda planificar las actividades de esta fase para poder llevar a cabo correctamente la recopilación y la revisión de los roles y de la documentación existente, que permitirá la ejecución de la siguiente fase de Evaluación.

La herramienta Excel asociada proporciona formularios estructurados que permiten registrar de manera ordenada las actividades, el equipo de trabajo, la revisión documental.

Planificación				
Actividad	Fecha estimada	Responsable		
Revisión de documentos	30/07/2025	Lopez		
Revisión técnica	30/07/2025	Sanchez		

Definición del equipo de trabajo		
Rol	Nombre	Función
Responsable ciberseguridad OT	Lopez	revisar documentos / Inspección OT
Responsable ciberseguridad IT	Sanchez	Inspección física OT
Operación de planta	Garcia	no participa al diagnóstico
Tecnología de información	Fernandez	no participa al diagnóstico
Tecnología operacionales	Raúl	apoyo al responsable OT
Mantenimiento	Iniesta	no participa al diagnóstico
Otro	-	-

Revisión documental previa				
Documentación	Sí/No	Ubicación	Responsable	Observaciones
Diagrama red OT	No	-	-	no existe
Diagrama de red IT	Sí	servidor	Sanchez	incompleto, ultima actualización junio 2020
Políticas de acceso	No	-	-	no existen formalizadas
Políticas de contraseña	Sí	directorio seguridad	Martínez	no incluyen dispositivos OT
Plan de contingencia	No	-	-	en proceso de elaboración
Plan de respuesta a incidentes	No	-	-	no existe actualmente
Inventario de activos OT	Sí	directorio infraestructura	Lopez	incompleto, ultima actualización junio 2020
Inventario de activos IT	Sí	directorio infraestructura	Sanchez	completo, no actualizado
Manuales de sistemas de control	Sí	desconocida	Garcia	existen, no se sabe donde están
Registros de actualizaciones	No	-	-	no existe
Registros de parches	No	-	-	no existe

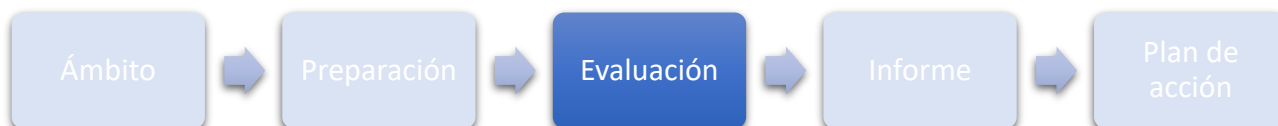
Ilustración 5. Ejemplo de cómo rellenar el formulario de la fase de Preparación

Un ejemplo práctico recomendado para llevar a cabo esta fase es:

Reunión inicial de planificación	• <i>Confirmar la fecha de revisión de documentos y la fecha de revisión técnica</i> • <i>Definir los responsables de cada tarea</i>
Rellenado de los formularios en la herramienta Excel	• <i>Registro del equipo de Trabajo</i> • <i>Revisión documental (qué existe, qué falta, donde está, responsables)</i>
Validación conjunta	• <i>Confirmación de los datos registrados</i> • <i>Planificación de la fase de Evaluación</i>

Tabla 3. Ejemplo de ejecución de la fase de Preparación

Evaluación



Tras las fases de Ámbito y Preparación, se inicia la fase de **Evaluación**. Esta etapa constituye el núcleo central del diagnóstico y tiene como objetivo evaluar el nivel de madurez en ciberseguridad de la organización.

La evaluación está compuesta por 90 controles divididos en 6 grandes áreas de la ciberseguridad:

- **Gobernanza:** estrategias, políticas y roles de gestión de la ciberseguridad
- **Seguridad de la Red:** protección y segmentación de la red
- **Control de acceso:** gestión de identidades, credenciales y privilegios
- **Protección de la Información:** confidencialidad, integridad y disponibilidad de los datos
- **Seguridad Física:** protección de los activos e infraestructuras físicas
- **Formación:** capacitación del personal

Estas áreas han sido adaptadas y simplificadas a partir de las categorías establecidas en marcos como el NIST SP800-82 y el NIST SP800-53, con el objetivo de facilitar su comprensión y aplicación por parte de personal no especializado, y al mismo tiempo mantener alineación con los principios fundamentales del NIST CSF.

Los controles permiten identificar el grado de exposición a amenazas, las debilidades técnicas y organizativas, las áreas críticas que requieren acción inmediata y las recomendaciones asociadas.

La fase de Evaluación se ha diseñado para que pueda ser realizada tanto por organizaciones con cierta experiencia en ciberseguridad como por aquellas que están dando sus primeros pasos. Justamente, el objetivo de esta metodología es reducir la barrera de entrada a la ciberseguridad y hacer accesible el diagnóstico a todas las organizaciones, independientemente de su madurez técnica o capacidad de inversión.

El enfoque práctico permite obtener una visión rápida pero útil de la situación actual y ejecutar un diagnóstico sin necesidad de herramientas, técnicas avanzadas, ni conocimientos profundos.

El evaluador interno designado para llevar a cabo la Evaluación deberá consultar, junto al equipo designado, los controles propuestos en cada una de las áreas. Para facilitar esta tarea, cada control está documentado en este documento mediante una tabla que contiene los siguientes campos:

Identificador	<i>código único del control, que permite su trazabilidad</i>
Control	<i>El nombre del control</i>
Por qué es importante	<i>justificación técnica u operativa de su relevancia</i>
Nivel de prioridad	<i>clasificación del control según su criticidad e impacto sobre la ciberseguridad.</i>
Riesgos si este control no existe	<i>consecuencias potenciales derivadas de la ausencia del control.</i>
Recomendaciones	<i>medidas prácticas para su implementación o mejora</i>
Referencia	<i>mapeo del control con estándares y marcos reconocidos (NIST, IEC 62443, etc.).</i>

Tabla 4. Ejemplo estructura de los campos que documentan los controles

Cada control se evalúa en función de su nivel de implementación, utilizando una escala de cinco niveles, como recomienda el NIST CSF:

Nivel	Definición	Indicadores clave	Que busca el evaluador
<i>Inexistente</i>	el control no existe ni se aplica	No hay procedimientos, herramientas, evidencias documentadas	No existe ningún indicio de que el control se haya aplicado o previsto
<i>Parcial</i>	existe de forma incompleta, informal, o con deficiencias significativas	Aplicación puntual, no hay documentación, no hay seguimiento	Existe alguna aplicación puntual, no hay control ni repetibilidad
<i>Básico</i>	existe de forma formalizada, pero con deficiencias y margen de mejora	Existen políticas o procedimientos, pero no se aplican o se aplican puntualmente	El control ha sido formalizado, pero tiene brechas, inconsistencias, no hay seguimiento
<i>Gestionado</i>	el control es implementado de forma estructurada y mantenido y supervisado	Existe documentación completa, mantenimiento, y evaluación periódica	El evaluador encuentra evidencias claras de que el control está integrado en la operación
<i>Optimizado</i>	el control es consolidado, con procesos de mejora continua y se audita	Existe evaluaciones regulares, procesos de mejora continua, monitorización, auditoría, integración con otros procesos	El evaluador encuentra evidencias de revisiones de los controles, automatización de los procesos, procedimientos de mejoras continuas y auditoria

Tabla 5. Guía de niveles de madurez para la evaluación de controles

Para facilitar su aplicación, la herramienta Excel proporciona la hoja de Evaluación que permite evaluar cada control registrando el nivel de implementación, automatizar el cálculo de indicadores en la hoja Dashboard para tener una visión compacta de la situación, anotar observaciones importantes y mapear cada control con las funciones, categorías y sub-categorías del NIST CSF, así como su referencia con estándares de ciberseguridad.

   Diagnóstico de Ciberseguridad para Infraestructuras de Agua									
Evaluación									
El objetivo de esta fase es evaluar el grado de cumplimiento de los controles de ciberseguridad aplicables a la instalación									
Fecha inicio evaluación:		01/07/2025			Fecha fin de evaluación: 13/07/2025				
ID	Área	Descripción del control	Estado	Revisión	NIST CSF	Referencia	Notas		
GO-001	Gobernanza	Existe un inventario de activos OT/IT actualizado, que incluye dispositivos físicos, software, aplicaciones, sistemas de terceros	0 - Inexistente	☒	ID.AM-01, ID.AM-02, ID.AM-04	NIST 800-53 CM-8, PM-5, Anexo I Guía	el inventario no está actualizado y no incluye los dispositivos de terceros		
GO-002	Gobernanza	Existe una persona designada como responsable de ciberseguridad OT, con capacitación y experiencia en entorno ICS, con apoyo visible y recursos proporcionados por la alta dirección	2 - Básico	☒	PR.AT-2, GV.RR-02, GV.RM-01, GV.OC-02	NIST SP 800-53 Rev 5.1.1 PM-09, PM-18, PM-30, RA-07, SR-02, SR-03, Taller CWP	se han designado todos los roles y la dirección apoya el responsable		
GO-003	Gobernanza	Existen responsabilidades de seguridad de la información claramente definidas y asignadas a los perfiles o roles correspondientes, incluidos partners, proveedores y clientes	3 - Gestionado	☐	GV.RR-01, ID.AM-6, GV.RM-01, GV.OC-02, GV.SC-02	Taller CWP	todas las responsabilidades están definidas		
GO-004	Gobernanza	La documentación de políticas y procedimientos se mantiene en un repositorio controlado, accesible solo al personal autorizado, garantizando su disponibilidad y actualización	4 - Optimizado	☒	GV.PO-01, GV.PO-02	MP-3 AWWA	se mantiene y audita periódicamente		
GO-005	Gobernanza	Existe un procedimiento que exige la evaluación y aprobación de los riesgos antes de permitir el acceso a los sistemas de información	No aplica	☐	GV.RM-01, GV.RM-03, ID.RA-10	NIST 800-53 CM-8, PM-5	no aplica		

Ilustración 6. Ejemplo práctico de aplicación de Evaluación

Ejemplo práctico de cómo llevar a cabo esta fase:

Revisión de los controles	- El evaluador interno, junto al equipo designado, analiza cada control definido en la hoja - Se consulta la documentación existente recopilada en la fase de Preparación - Se recogen evidencias cuando sea posible
Registro de la evaluación	Se asigna a cada control el nivel de implementación correspondiente. A continuación, ejemplos prácticos que muestran como evaluar el nivel de los controles: - Control de Acceso CA-004, Se modifican las contraseñas por defecto en todos los sistemas IT/OT - Inexistente: Todos los dispositivos mantienen las contraseñas por defecto del fabricante - Parcial: Algunos dispositivos críticos han sido configurados, pero otros aún mantienen credenciales por defecto. No existe una política clara

	<i>Básico: se ha establecido una política interna para el cambio de contraseñas, pero no se realiza un seguimiento sistemático</i> <i>Gestionado: Todos los dispositivos tienen contraseñas seguras únicas. Se revisan periódicamente según procedimientos definidos</i> <i>Optimizado: Gestionado + autenticación multifactor, auditoría periódica</i> - <i>Formación FO-004, Se realiza formación anual de concienciación sobre ciberseguridad para todo el personal de la instalación que cubre conceptos básicos de ciberseguridad</i> <i>Inexistente: No se realizan actividades formativas sobre ciberseguridad</i> <i>Parcial: algunos empleados han recibido formación, pero no está planificada ni documentada</i> <i>Básico: se ha realizado un curso básico para el personal técnico, pero sin periodicidad</i> <i>Gestionado: la formación está documentada, es periódica, se adapta a los roles y hay registro de participantes</i> <i>Optimizado: Gestionado + simulacros de phishing, evaluaciones, mejoras de los contenidos</i> - <i>Seguridad de la red SR-001 Existe una separación lógica entre la red de control y la red corporativa, con puntos de acceso mínimos y controlados para limitar los movimientos laterales y proteger los sistemas críticos</i> <i>Inexistente: No hay separación entre la red IT y OT, todo está en la misma subred</i> <i>Parcial: Hay cierta separación (por ejemplo, VLANs), pero sin control de tráfico ni reglas específicas</i> <i>Básico: Se implementa una separación física o lógica clara, con reglas mínimas</i> <i>Gestionado: hay segmentación robusta con firewalls o routers y políticas de tráfico</i> <i>Optimizado: Gestionado + monitorización activa de tráfico entre segmentos y revisión de reglas periódicas</i> <i>Se documentan observaciones relevantes para el evaluador</i>
--	---

	<i>Es importante completar el campo Fecha fin de evaluación para poder generar recomendaciones de fechas límite en el Plan de acción para la mitigación de las vulnerabilidades</i>
Revisión de resultados	La herramienta Excel calcula automáticamente los indicadores en la hoja Dashboard

Tabla 6. Ejemplo ejecución de la fase de Evaluación

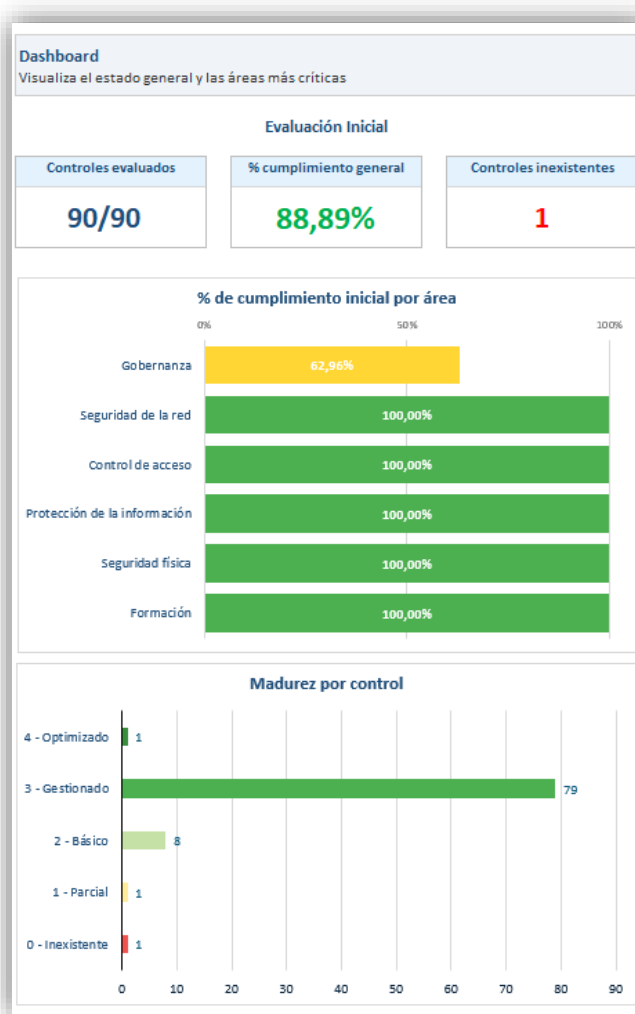


Ilustración 7. Indicadores de Evaluación Inicial

La hoja Dashboard de la herramienta Excel proporciona una visión de la Evaluación inicial y de la Situación actual (que se actualiza con los datos del Plan de acción). Estos indicadores permiten tener una visión rápida del nivel de cumplimiento general, identificar las áreas críticas que requieren atención primaria y comprender la distribución de los niveles de los controles evaluados.

A continuación, se explica el significado de cada indicador y como interpretar su resultado.

- **Controles evaluados:** este indicador muestra la cantidad de controles analizados durante la evaluación en relación con el total (90 controles)
- **Cumplimiento general:** muestra el porcentaje global inicial de cumplimiento de la organización, basado en la cantidad de controles que se consideran implementados adecuadamente (3 – Gestionado, 4 – Optimizado), excluyendo los que están evaluados como Inexistente, Parcial, Básico. Un porcentaje alto (>75%) indica buena madurez general. Un porcentaje bajo (<50%) evidencia importantes carencias de seguridad.
- **Controles inexistentes:** es la cantidad de controles que se han evaluado como Inexistentes, es decir que no están implementados y que la presencia de controles inexistentes indica puntos críticos que deben ser priorizados
- **Gráfico % de cumplimiento inicial por área:** representa el porcentaje de cumplimiento en cada una de las seis áreas de evaluación. Este indicador permite focalizar los esfuerzos en las áreas más débiles.
- **Gráfico Madurez por control:** muestra la distribución de los 90 controles evaluados según su nivel de madurez

A continuación, se presentan las seis áreas que estructuran el proceso de evaluación. Para cada área se incluye una breve descripción, que explica su propósito y las tablas que contienen todos los controles definidos para cada área, acompañados de sus justificaciones, sus recomendaciones y sus referencias.

Gobernanza

La gobernanza se refiere al conjunto de políticas, procedimientos y procesos que definen como una organización gestiona su ciberseguridad para reducir el riesgo cibernético.

Con la gobernanza, la dirección de una organización integra la gestión del riesgo digital dentro de su planificación estratégica, asignando recursos, definiendo responsabilidades y estableciendo políticas claras y permitiendo coordinar los aspectos técnicos, físicos, operativos y organizativos de la seguridad[36].

En esta área, el diagnóstico evalúa si la organización tiene definidos roles y responsabilidades en ciberseguridad, si se han establecido políticas documentadas y procedimientos, si realizan revisiones periódicas de todas las políticas.

Identificador	GO-001
Control	Existe un inventario de activos OT/IT actualizado, que incluye dispositivos físicos, software, aplicaciones, sistemas de terceros
Por qué es importante	Disponer de un inventario actualizado permite conocer qué dispositivos y sistemas están conectados a la red, gestionar sus configuraciones, detectar equipos obsoletos o no autorizados, y aplicar medidas de protección adecuadas
Nivel de prioridad	Crítico
Riesgos si este control no existe	Dispositivos no autorizados o vulnerables conectados sin supervisión Dificultad para responder a incidentes Falta de cumplimiento normativo
Recomendaciones	Elaborar y mantener un inventario centralizado de todos los dispositivos IT/OT de la organización
Referencia	NIST 800-53r5 CM-8, PM-5, Anexo I Guía

Identificador	GO-002
Control	Existe una persona designada como responsable de ciberseguridad OT, con capacitación y experiencia en entorno ICS, con apoyo visible y recursos proporcionados por la alta dirección
Por qué es importante	Contar con un responsable claramente asignado permite coordinar de manera efectiva las políticas, acciones y respuesta ante incidentes de ciberseguridad y la gestión de riesgos. Las redes y sistemas OT tienen características, riesgos y requerimientos distintos a los entornos IT. Designar un responsable específico permite asegurar que las acciones de ciberseguridad sean adecuadas al contexto industrial
Nivel de prioridad	Crítico
Riesgos si este control no existe	Falta de coordinación en las acciones de seguridad Ausencia de liderazgo técnico Respuestas ineficientes ante incidentes Retrasos en la implementación de controles Descoordinación entre seguridad IT y OT Medidas inapropiadas para entornos industriales Mayor exposición a riesgos operativos Respuestas ineficientes ante incidentes OT
Recomendaciones	Asignar la responsabilidad de ciberseguridad OT a una persona con conocimiento del entorno industrial
Referencia	NIST SP 800-53 Rev 5.1.1 PM-09, PM-18, PM-30, RA-07, SR-02, SR-03

Identificador	GO-003
Control	Existen responsabilidades de seguridad de la información claramente definidas y asignadas a los perfiles o roles correspondientes, incluidos partners, proveedores y clientes
Por qué es importante	Definir y asignar responsabilidades asegura que los controles de seguridad no se queden en papel, sino que haya personas responsables de su ejecución, seguimiento y mejora. También permite establecer líneas claras de autoridad y respuesta ante incidentes
Nivel de prioridad	Crítico
Riesgos si este control no existe	Falta de cumplimiento normativo Falta de seguimiento Respuesta ineficaz ante incidentes Desorganización
Recomendaciones	Establecer formalmente las funciones y responsabilidades en materia de seguridad de la información
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-004
Control	La documentación de políticas y procedimientos se mantiene en un repositorio controlado, accesible solo al personal autorizado, garantizando su disponibilidad y actualización
Por qué es importante	Garantiza que todo el personal esté informado y alineado con los procedimientos de seguridad
Nivel de prioridad	No crítico
Riesgos si este control no existe	El personal actúa con base en documentos desactualizados o inexistentes Las respuestas a incidentes o emergencias son ineficaces Falta de cumplimiento normativo
Recomendaciones	Crear un repositorio estructurado y establecer un responsable para el documento de revisión y el documento de actualización. Formar al personal sobre cómo consultar los documentos
Referencia	MP-3 AWWA

Identificador	GO-005
Control	Existe un procedimiento que exige la evaluación y aprobación de los riesgos antes de permitir el acceso a los sistemas de información
Por qué es importante	Garantiza que cada acceso a los sistemas de información de la organización esté controlado y documentado y no otorgue accesos a sistemas de información sin una evaluación previa de riesgos por parte de responsables designados
Nivel de prioridad	1
Riesgos si este control no existe	Fuga de información Accesos innecesarios a sistemas críticos Falta de cumplimiento normativo Persistencia de cuentas antiguas o no revocadas Dificultad a la hora de identificar un incidente de seguridad
Recomendaciones	Aplicar el principio de mínimos privilegios y acceso basado en roles. Establecer un procedimiento de evaluación y aprobación de riesgos para todas las solicitudes de acceso a sistemas críticos
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-006
Control	Se mantiene un registro actualizado de normativas aplicables a los sistemas OT (NIS2, ISO 27001, IEC 62443, etc)
Por qué es importante	Conocer y seguir las normativas aplicables permite asegurar el cumplimiento legal y regulatorio, anticipar requisitos futuros, y alinear las medidas de seguridad con estándares reconocidos. En sectores críticos como el agua, este control es esencial para evitar sanciones y mejorar la madurez de ciberseguridad
Nivel de prioridad	Crítico
Riesgos si este control no existe	Falta de cumplimiento normativo Riesgos de sanciones legales Riesgos de aplicación de controles inadecuados o insuficientes
Recomendaciones	Crear un registro interno donde se identifiquen todas las normativas relevantes para la organización. Asignar un responsable de su seguimiento y actualización
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-007
Control	Existen políticas y procedimientos para la retención y eliminación segura de datos sensibles, que incluyen el borrado seguro de medios de almacenamiento
Por qué es importante	Gestionar adecuadamente la retención y eliminación de datos reduce el riesgo de exposición de información sensible, asegura el cumplimiento normativo y libera recursos innecesariamente ocupados. Eliminar datos de forma segura es crítico para prevenir accesos no autorizados, especialmente al finalizar su utilidad operativa
Nivel de prioridad	Crítico
Riesgos si este control no existe	Retención innecesaria de información sensible Fuga de datos Falta de cumplimiento normativo Acceso indebido a datos residuales
Recomendaciones	Establecer políticas que definan qué tipos de datos deben ser retenidos, por cuánto tiempo y cómo deben eliminarse de forma segura. Aplicar mecanismos como borrado seguro, sobreescritura o destrucción física de medios
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-008
Control	La instalación parcha o mitiga vulnerabilidades conocidas dentro del tiempo recomendado. Los parches de seguridad se aplican de forma controlada y validada en los sistemas críticos conforme a las buenas prácticas de ciberseguridad
Por qué es importante	Las vulnerabilidades conocidas son uno de los vectores de ataque más comunes. Abordarlas en plazos razonables permite reducir significativamente la superficie de ataque y prevenir incidentes explotables mediante técnicas automatizadas o campañas dirigidas
Nivel de prioridad	Crítico
Riesgos si este control no existe	Persistencia de vulnerabilidades explotables Compromiso de sistemas críticos Pérdida de datos Acceso no autorizado Daños reputacionales
Recomendaciones	Establecer un proceso formal para evaluar, priorizar y aplicar parches o medidas compensatorias
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-009
Control	La organización define políticas de control de acceso basadas en el principio de privilegio mínimo, garantizando que los usuarios solo dispongan de los permisos estrictamente necesarios para desempeñar sus funciones
Por qué es importante	El objetivo de este control es reducir la superficie de ataque y los riesgos asociados a accesos innecesarios, tanto para usuarios legítimos como para actores maliciosos
Nivel de prioridad	Crítico
Riesgos si este control no existe	Cuentas con privilegios innecesarios expuestas a explotación Movimiento lateral de atacantes dentro de la red una vez comprometido un usuario Cambios no autorizados en sistemas críticos Falta de cumplimiento regulatorio
Recomendaciones	Elaborar una política de control de privilegios mínimos. Crear una matriz de accesos por rol/función en la organización. Implementar un proceso formal de aprobación de accesos. Revisar todos los accesos actuales y revocar los innecesarios. Implementar mecanismos de revisión periódica de permisos
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-010
Control	Existe un proceso de acuerdo con terceros para garantizar que los proveedores y contratistas externos utilizan las medidas de seguridad adecuadas para acceder, procesar, comunicar o gestionar la información o las instalaciones de la organización
Por qué es importante	Garantiza que cualquier acceso o comunicación con la infraestructura esté seguro y controlado mediante acuerdos formales y prácticas seguras
Nivel de prioridad	Crítico
Riesgos si este control no existe	Acceso no autorizado Manipulación de datos Pérdida de datos Filtración de datos Falta de cumplimiento normativo Malware introducido
Recomendaciones	Establecer políticas de seguridad para terceros. Incluir cláusulas de seguridad en todos los acuerdos y contratos con terceros y exigir cumplimiento de seguridad a los terceros. Implementar procedimientos de gestión de acceso otorgados a terceros
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-011
Control	Existe una plantilla para los acuerdos de confidencialidad/no divulgación de la organización definidos, revisados y aprobados periódicamente por la dirección
Por qué es importante	Los acuerdos de confidencialidad (NDA) ayudan a proteger información sensible relacionada con procesos industriales, patentes, datos operativos, vulnerabilidades, etc. Un acuerdo actualizado y formalizado es importante para controlar la divulgación indebida por parte de empleados o terceros
Nivel de prioridad	No crítico
Riesgos si este control no existe	Falta de cumplimiento legal Falta de cumplimiento contractual Robo de información sensible
Recomendaciones	Establecer una plantilla estandarizada de NDA revisada y aprobada por la dirección y aplicarla a todas las personas que tienen acceso a información sensible de la empresa
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-012
Control	Existen políticas de seguridad de equipos autónomos, perdidos y extraviados
Por qué es importante	Los equipos empresariales contienen información sensible. Tener políticas que controlan la pérdida de dispositivos ayuda a reaccionar rápidamente, limitar el impacto y definir responsabilidades
Nivel de prioridad	No crítico
Riesgos si este control no existe	Fuga de información confidencial Acceso no autorizado a sistemas corporativos
Recomendaciones	Definir una política clara para la gestión de equipos extraviados, incluyendo mecanismos de revocación de acceso y borrado remoto
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-013
Control	Existen políticas y procedimientos para el uso aceptable de activos e información aprobados y aplicados
Por qué es importante	Establecer normas claras de uso aceptable ayuda a reducir comportamientos de riesgo, prevenir mal uso intencionado o accidental de recursos y proteger la integridad de los sistemas operativos y la información crítica.
Nivel de prioridad	No crítico
Riesgos si este control no existe	Uso indebido de sistemas Exposición a malware Fuga de información
Recomendaciones	Implementar una política de uso aceptable que cubra navegación en internet, correo electrónico, uso de dispositivos personales, almacenamiento de datos, acceso remoto
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-014
Control	Se realiza una revisión periódica de las políticas y procedimientos de copia de seguridad
Por qué es importante	Las políticas de copia de seguridad sirven para definir qué datos deben protegerse, cómo y con qué frecuencia. Si no se hace una revisión periódica, pueden quedar desactualizadas frente a cambios en la infraestructura, riesgos emergentes o nuevas regulaciones
Nivel de prioridad	No crítico
Riesgos si este control no existe	Perdida de datos críticos Falta de cumplimiento normativo
Recomendaciones	Establecer un calendario de revisión y validación de las políticas de respaldo
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-015
Control	Se realiza una revisión periódica de las políticas y procedimientos de comprobación de los procesos de recuperación
Por qué es importante	Este control sirve para asegurarse que los procedimientos de recuperación funcionen correctamente y asegurarse de que, en caso de incidente, se pueda restaurar el servicio en el tiempo esperado
Nivel de prioridad	No crítico
Riesgos si este control no existe	Fallos en la recuperación de sistemas Tiempo prolongado de inactividad Pérdida de información crítica
Recomendaciones	Establecer un programa de revisión periódica de las políticas y procedimientos recuperación ante incidentes
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-016
Control	Existen políticas y procedimientos que permiten verificar, mantener y mejorar el plan de continuidad de negocio
Por qué es importante	Asegura que la organización esté preparada para la recuperación y continuidad de negocio ante incidentes inesperados, garantizando tiempos mínimos de inactividad y controlando el impacto
Nivel de prioridad	Crítico
Riesgos si este control no existe	Interrupciones graves en las operaciones Falta de preparación para desastres que puede derivar en pérdida de datos, daños reputacionales, problemas financieros Falta de cumplimiento normativo
Recomendaciones	Desarrollar y documentar un plan de continuidad de negocio y designar un equipo responsable de la actualización y revisión del plan
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-017
Control	Existe un plan de continuidad de negocio que considera específicamente la continuidad de distribución/tratamiento de agua ante un ataque o fallo cibernético en sistemas industriales (PLC, SCADA)
Por qué es importante	La continuidad del suministro de agua depende de múltiples elementos críticos, incluyendo sistemas industriales. Los incidentes cibernéticos pueden paralizar los procesos de tratamiento o distribución, por lo que deben estar contemplados explícitamente en el plan de continuidad
Nivel de prioridad	Crítico
Riesgos si este control no existe	Interrupción prolongada del suministro de agua Incapacidad de respuesta ante incidentes Riesgos para la salud pública
Recomendaciones	Integrar en el plan de continuidad escenarios de ataque o fallo de tecnologías industriales
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-018
Control	El Plan de Respuesta a Incidentes es actualizado y probado regularmente
Por qué es importante	Un plan desactualizado o no probado puede fallar cuando más se necesita. La actualización y las pruebas periódicas aseguran que los roles, procedimientos, tecnologías y amenazas estén correctamente contemplados, y que el personal sepa cómo actuar ante un incidente real
Nivel de prioridad	Crítico
Riesgos si este control no existe	Fallos en la respuesta ante incidentes
Recomendaciones	Establecer un calendario de revisión del plan de respuesta a incidentes. Realizar simulacros regulares que involucren todo el personal
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-019
Control	Se dispone de procedimientos de emergencia específicos para incidentes cibernéticos que puedan comprometer la calidad del agua o interrumpir los procesos de bombeo o tratamiento
Por qué es importante	Contar con protocolos y procedimientos claros de actuación ante incidentes de ciber seguridad es fundamental para mitigar el impacto que puede afectar tanto la calidad del agua como la operación de las infraestructuras críticas como de bombeo o tratamiento del agua
Nivel de prioridad	Crítico
Riesgos si este control no existe	Contaminación del agua y riesgos para la salud pública Falta de cumplimiento normativo Exposición a sanciones regulatorias Pérdida de reputación
Recomendaciones	Establecer procedimientos de emergencia específicos para incidentes cibernéticos que afecten la calidad del agua o el funcionamiento de sistemas OT
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-020
Control	Se han establecido protocolos de coordinación con autoridades locales para la gestión de incidentes críticos
Por qué es importante	Es importante tener protocolos claros que mejoren la coordinación con las autoridades locales (protección civil, cuerpos de seguridad, autoridades sanitarias) para responder de manera eficaz a incidentes de críticos de ciber seguridad
Nivel de prioridad	Crítico
Riesgos si este control no existe	Falta de coordinación en situaciones críticas Falta de cumplimiento normativo Pérdida de la reputación
Recomendaciones	Establecer protocolos formales de colaboración con las autoridades, incluyendo canales de comunicación, puntos de contactos, roles, prácticas conjuntas
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-021
Control	Existe un protocolo de coordinación y comunicación formal entre las empresas responsables de la depuración y la distribución del agua
Por qué es importante	Es importante contar un protocolo de coordinación y comunicación en entornos donde distintas entidades gestionan fases diferentes del ciclo del agua, para garantizar la seguridad, continuidad operativa y respuesta ante incidentes
Nivel de prioridad	Crítico
Riesgos si este control no existe	Respuesta descoordinada ante incidentes Riesgos para la seguridad pública
Recomendaciones	Establecer un protocolo formal entre entidades con funciones interdependientes como por ejemplo depuración y distribución, definiendo canales de comunicación, puntos de contacto y protocolos de respuesta conjunta ante incidentes de ciberseguridad
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-022
Control	Se evalúan los riesgos de ciberseguridad en la cadena de suministro (proveedores críticos)
Por qué es importante	Los proveedores son un vector habitual de ataques cibernéticos. La interrupción o compromiso de un proveedor crítico, en especial aquellos que suministran equipos, software, telecomunicaciones o servicios OT, puede comprometer la integridad, disponibilidad o seguridad de los sistemas de agua. Evaluar estos riesgos es esencial para proteger la infraestructura crítica
Nivel de prioridad	Crítico
Riesgos si este control no existe	Compromiso de sistemas a través de proveedores Sabotaje, manipulación o inserción de vulnerabilidades Interrupción en el suministro de bienes o servicios críticos Pérdida de control sobre los entornos OT
Recomendaciones	Implementar un proceso formal de gestión de riesgos de la cadena de suministro cibernética (C-SCRM), incluyendo: evaluaciones de riesgo previas a la contratación de proveedores críticos; exigencia de controles mínimos de seguridad documentados; supervisión continua y revisión de riesgos asociados a terceros; integración de la ciberseguridad en los contratos y acuerdos de nivel de servicio
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-023
Control	Los proveedores que acceden a sistemas OT deben cumplir requisitos de ciberseguridad documentados
Por qué es importante	El acceso externo no controlado o con requisitos débiles aumenta el riesgo de ataques, sabotajes o malfuncionamientos. Documentar y exigir requisitos robustos es fundamental para preservar la seguridad y resiliencia de las operaciones.
Nivel de prioridad	Crítico
Riesgos si este control no existe	Accesos no autorizados a entornos OT Interrupciones o daños en los sistemas de control industrial Pérdida de integridad en los procesos de tratamiento o distribución Riesgo para la salud pública y el medio ambiente
Recomendaciones	Definir requisitos de ciberseguridad específicos para todos los proveedores que acceden a sistemas OT (políticas, estándares, controles mínimos). Documentar dichos requisitos en contratos, acuerdos de nivel de servicio y procesos de onboarding. Exigir evidencia de cumplimiento y realizar auditorías periódicas. Integrar controles de acceso técnico (VPN, autenticación multifactor, segmentación de red)
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-024
Control	La organización requiere que todos los proveedores y contratistas OT notifiquen cualquier incidente de seguridad o vulnerabilidad en un plazo informado por riesgo
Por qué es importante	La colaboración con proveedores es esencial para mantener la seguridad en entornos OT. Requerir la notificación oportuna de incidentes o vulnerabilidades permite actuar con rapidez para mitigar riesgos que podrían afectar a la organización directamente
Nivel de prioridad	Crítico
Riesgos si este control no existe	Vulnerabilidades explotables sin conocimiento de la organización Retraso en la respuesta ante incidentes que afectan a componentes de terceros Incremento del riesgo residual asociado a la cadena de suministro
Recomendaciones	Incluir en todos los contratos cláusulas que obliguen a los proveedores a notificar incidentes y vulnerabilidades que puedan afectar a sus productos, servicios o integraciones
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-025
Control	Existe un programa de detección y análisis de fraudes de consumo de agua basado en el cruce de datos de mediciones y patrones históricos
Por qué es importante	El fraude de consumo de agua no solo implica pérdidas económicas, sino que puede ocultar manipulaciones técnicas, sabotajes o accesos ilegales que comprometen la integridad operativa o la seguridad del sistema. El análisis proactivo de datos permite identificar desviaciones anómalas y actuar con rapidez
Nivel de prioridad	No crítico
Riesgos si este control no existe	Fugas no controladas Fraude Pérdida de ingresos
Recomendaciones	Implementar un sistema de monitoreo basado en análisis de big data que crucen consumos históricos, patrones esperados, eventos de mantenimiento
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-026
Control	Se mantiene contacto con autoridades y grupos profesionales para mantener actualizado el conocimiento de amenazas
Por qué es importante	Las amenazas cibernéticas evolucionan constantemente. Estar conectado con redes de intercambio de información (ISACs, CSIRTs, asociaciones del sector, autoridades reguladoras) permite anticiparse a riesgos, aplicar parches oportunos y adaptar los planes de defensa a la realidad actual
Nivel de prioridad	1
Riesgos si este control no existe	Desconocimiento de vulnerabilidades críticas Mayor exposición ante campañas activas
Recomendaciones	Establecer un canal y un responsable para recibir y aplicar las recomendaciones de agencias como INCIBE, ENISA o el CSIRT
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	GO-027
Control	Existen políticas y procedimientos para la instalación o el despliegue de nuevos programas informáticos
Por qué es importante	La falta de políticas o controles en el despliegue de software puede introducir vulnerabilidades y comprometer la integridad del sistema. Las políticas aseguran que todo el software que se instala sea evaluado y aprobado antes de su uso
Nivel de prioridad	1
Riesgos si este control no existe	Instalación de software malicioso Ransomware
Recomendaciones	Definir un procedimiento formal de aprobación, evaluación e instalación de cualquier software nuevo en la organización
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Seguridad de la Red

La seguridad de la red se centra en proteger la infraestructura de comunicaciones que conecta las redes IT y OT.

Estos controles evalúan la arquitectura de red, la segmentación lógica y física, la monitorización del tráfico, el uso de firewall, DMZ y sistemas IDS/IPS.

Identificador	SR-001
Control	Existe una separación lógica entre la red de control y la red corporativa, con puntos de acceso mínimos y controlados para limitar los movimientos laterales y proteger los sistemas críticos
Por qué es importante	Este control asegura que las redes de control industrial (OT) y las corporativas (IT) estén separadas lógicamente, evitando que amenazas en la red IT afecten los procesos críticos
Nivel de prioridad	Crítico
Riesgos si este control no existe	Acceso no autorizado desde la red corporativa a los sistemas de control industrial Propagación de malware Pérdida de disponibilidad de procesos críticos Escalada de privilegios desde usuarios corporativos
Recomendaciones	Implementar una segmentación lógica de la red utilizando VLANs, firewalls y zona de DMZ. Minimizar los puntos de acceso entre redes y controlar el tráfico mediante políticas específicas.
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SR-002
Control	Hay segmentación entre las redes OT e IT y se deniega la conexión a la red OT por defecto a menos que se permita explícitamente
Por qué es importante	Aplicar una política de denegación por defecto garantiza que únicamente se establezcan conexiones necesarias, verificadas y controladas hacia la red OT, reduciendo la superficie de ataque y evitando accesos no autorizados desde entornos menos protegidos
Nivel de prioridad	Crítico
Riesgos si este control no existe	Conexiones innecesarias o no autorizadas desde IT hacia OT Movimientos laterales Propagación de malware Manipulación remota de ISC desde la red IT
Recomendaciones	Configurar firewalls y dispositivos de control de acceso para que bloqueen todo el tráfico hacia la red OT salvo aquellas conexiones explícitamente autorizadas, que deben ser validadas y documentadas
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance, Anexo III

Identificador	SR-003
Control	Las redes están segregadas mediante cortafuegos
Por qué es importante	Los cortafuegos permiten controlar el tráfico entre segmentos de red, aplicar políticas de acceso estrictas y registrar intentos de conexión no autorizados. Son fundamentales para prevenir movimientos laterales de amenazas entre entornos IT y OT o entre diferentes zonas operativas
Nivel de prioridad	Crítico
Riesgos si este control no existe	Propagación de malware Falta de control sobre el tráfico entrante y saliente
Recomendaciones	Implementar cortafuegos en todos los puntos de conexión entre redes diferentes
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SR-004
Control	Se utilizan redes DMZ para compartir datos entre sistemas OT e IT
Por qué es importante	Las DMZ es una zona intermedia que facilita el intercambio de datos entre red OT y red IT sin comprometer la seguridad operativa
Nivel de prioridad	Crítico
Riesgos si este control no existe	Propagación de malware Explotación de vulnerabilidades Movimientos laterales Ransomware
Recomendaciones	Implementar una red DMZ para todo intercambio de datos entre redes IT y OT. Hay que asegurar que los servidores en la DMZ sean los únicos que acceden a sistemas OT y que este acceso esté controlado, monitoreado y limitado al mínimo necesario
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SR-005
Control	Se aplican políticas estrictas de microsegmentación de red para separar dispositivos críticos OT de otros dispositivos IT o IIoT
Por qué es importante	La microsegmentación reduce la superficie de ataque al limitar la comunicación entre dispositivos a lo estrictamente necesario. Es especialmente útil en entornos industriales donde conviven sistemas legados, dispositivos críticos OT y nuevas tecnologías conectadas (IIoT), y permite contener ataques dentro de segmentos reducidos
Nivel de prioridad	Crítico
Riesgos si este control no existe	Propagación de malware Ransomware Compromiso de dispositivos críticos desde IIoT
Recomendaciones	Implementar microsegmentación mediante el uso de VLANs, firewalls, ACLs. Definir qué dispositivos pueden comunicarse entre sí y en qué condiciones
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SR-006
Control	Existe un identificador SSID único asignado exclusivamente a la red inalámbrica de control, diferenciándola de otras redes
Por qué es importante	Utilizar un SSID exclusivo para la red de control inalámbrica ayuda a aislarla de redes generales o de invitados, facilitando la aplicación de políticas de seguridad diferenciadas y reduciendo el riesgo de accesos no autorizados o interferencias
Nivel de prioridad	No crítico
Riesgos si este control no existe	Posibilidad de conexión no autorizadas Exposición de sistemas críticos a ataques
Recomendaciones	Configurar un SSID exclusivo para la red de control, aplicando autenticación fuerte, aislamiento del tráfico y políticas de QoS
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SR-007
Control	Se minimiza la cobertura de la red inalámbrica para reducir exposición innecesaria
Por qué es importante	Las señales inalámbricas pueden extenderse más allá del perímetro físico de las instalaciones, exponiendo la red a potenciales ataques desde el exterior. Reducir su cobertura a lo necesario disminuye la posibilidad de accesos no autorizados y ataques remotos
Nivel de prioridad	No crítico
Riesgos si este control no existe	Acceso no autorizado desde el exterior Ataques de fuerza bruta Ataque de deauth Interceptación de tráfico Explotación de debilidades/vulnerabilidades sin necesidad de acceso físico
Recomendaciones	Ajustar la potencia de emisión de los puntos de acceso para que la cobertura solo abarque las áreas operativas necesarias
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SR-008
Control	Los dispositivos inalámbricos industriales están ubicados en una red aislada con una conexión mínima o única a la red de control
Por qué es importante	Los dispositivos inalámbricos industriales pueden ser más vulnerables a intrusiones y manipulación. Ubicarlos en redes separadas y controladas minimiza los riesgos de propagación de amenazas hacia el núcleo del sistema OT
Nivel de prioridad	Crítico
Riesgos si este control no existe	Propagación de malware
Recomendaciones	Establecer redes separadas para los dispositivos inalámbricos. Implementar gateways o firewalls con reglas estrictas para filtrar la comunicación entre estos dispositivos y la red OT
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SR-009
Control	Se eliminan todas las conexiones directas entre los activos OT e Internet
Por qué es importante	Las conexiones directas a Internet exponen sistemas industriales a ataques remotos, explotación de vulnerabilidades, escaneos automatizados y amenazas persistentes avanzadas. Eliminar estas conexiones es una medida fundamental para proteger la disponibilidad, integridad y confidencialidad de los procesos críticos
Nivel de prioridad	Crítico
Riesgos si este control no existe	Acceso remoto no autorizado Ransomware Interrupción o manipulación de procesos industriales
Recomendaciones	Revisar todas las configuraciones de red para identificar y eliminar accesos directos desde activos OT a internet
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SR-010
Control	Se garantiza que los activos conectados a la Internet pública no exponen servicios explotables innecesarios
Por qué es importante	Exponer servicios innecesarios a Internet, como RDP, FTP o puertos de administración sin protección, amplía la superficie de ataque y permite que actores maliciosos encuentren y exploten vulnerabilidades comunes
Nivel de prioridad	Crítico
Riesgos si este control no existe	Ataques automatizados Explotación de vulnerabilidades conocidas Acceso remoto no autorizado Ransomware Escalada de privilegios Exfiltración de información sensible
Recomendaciones	Realizar un inventario de todos los servicios accesibles desde Internet y cerrar aquellos no indispensables
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SR-011
Control	Se utilizan IDS/IPS basados en anomalías para detectar comportamientos inusuales
Por qué es importante	Los IDS/IPS basados en anomalías permiten detectar ataques desconocidos, movimientos laterales o manipulaciones sutiles en redes industriales
Nivel de prioridad	1
Riesgos si este control no existe	No detectar ataques que no se basan en firmas conocidas
Recomendaciones	Implementar IDS/IPS con capacidad de detección basada en anomalías
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SR-012
Control	Se ha implementado un sistema de gestión de eventos e información de seguridad (SIEM) que centraliza y correlaciona los registros de los sistemas críticos
Por qué es importante	La centralización de los logs permite tener una visibilidad integral de todo el sistema, permitiendo detectar patrones de ataques y analizar incidentes
Nivel de prioridad	No crítico
Riesgos si este control no existe	Falta de visibilidad Detección tardía de incidentes Falta de cumplimiento normativo
Recomendaciones	Implementar un SIEM y configurar todos los dispositivos para que envíen sus eventos al SIEM
Referencia	

Identificador	SR-013
Control	Existe un sistema de sincronización horaria centralizado en todos los sistemas de la organización
Por qué es importante	La sincronización horaria garantiza que los registros de eventos, alertas, logs y datos de sistemas distribuidos (IT y OT) tengan marcas de tiempo coherentes, lo cual es esencial para la detección, análisis y respuesta ante incidentes de ciberseguridad
Nivel de prioridad	No crítico
Riesgos si este control no existe	Dificultades en la correlación de eventos Errores en análisis forense Alertas sin contexto temporal preciso
Recomendaciones	Implementar un servidor NTP interno (sincronizado con fuentes confiables) y configurar todos los sistemas para utilizar esta fuente
Referencia	

Identificador	SR-014
Control	Se ha identificado y documentado la presencia de dispositivos OT legacy que no reciben actualizaciones de seguridad y se han implementado medidas de seguridad compensatorias para mitigar los riesgos asociados
Por qué es importante	Porque tener documentada la presencia de dispositivos OT legacy permite monitorizarlos, aislarlos o aplicar controles compensatorios y reducir el riesgo de que se conviertan en vectores de ataque
Nivel de prioridad	Crítico
Riesgos si este control no existe	Desconocimiento del riesgo Acceso no autorizado Interrupciones de servicio Vulnerabilidades conocidas fácilmente explotables
Recomendaciones	Mantener un inventario detallado de todos los dispositivos OT legacy, documentando su estado de soporte y aplicando controles compensatorios. Minimizar su exposición
Referencia	

Identificador	SR-015
Control	Existen controles compensatorios específicos para dispositivos OT que no pueden ser actualizados (por ejemplo, segmentación, aislamiento)
Por qué es importante	Cuando no es posible aplicar parches o actualizaciones a ciertos dispositivos críticos, es necesario implementar controles adicionales que reduzcan su exposición y mitiguen el riesgo de explotación. Sin estos controles, los dispositivos legacy siguen siendo un punto débil aprovechable por atacantes
Nivel de prioridad	Crítico
Riesgos si este control no existe	Alta probabilidad de explotación de vulnerabilidades conocidas Movimientos laterales Interrupciones de procesos Riesgo de comprometer las redes OT
Recomendaciones	Aplicar controles compensatorios como segmentación de red, firewalls internos, restricciones de acceso físico y lógico, monitorización y reducir la exposición a Internet
Referencia	

Identificador	SR-016
Control	Se mantiene una documentación actualizada que describa la topología de la red a través de las redes OT e IT de la planta
Por qué es importante	Es importante para detectar configuraciones inseguras, responder eficazmente ante incidentes, aplicar bien las políticas e identificar puntos críticos
Nivel de prioridad	Crítico
Riesgos si este control no existe	Falta de visibilidad sobre la infraestructura que puede derivar en vulnerabilidades graves Dificultad para aplicar controles de seguridad Dificultad para restaurar operaciones tras un incidente
Recomendaciones	Mantener un diagrama actualizado de la infraestructura
Referencia	ID.AM

Control de Acceso

El control de acceso se refiere a los mecanismos que aseguran que únicamente las personas autorizadas puedan acceder a los sistemas datos y dispositivos y que tengan los permisos mínimos necesarios para poder hacerlo.

Estos controles evalúan la existencia de cuentas y privilegios, los controles de sesiones, la autenticación fuerte, la segregación de accesos, la revocación de acceso, entre otros.

Identificador	CA-001
Control	Existe un sistema de control de acceso basado en roles (RBAC) respaldado por políticas y procedimientos documentados
Por qué es importante	El modelo RBAC permite asignar permisos en función de los roles de cada usuario, evitando accesos innecesarios y reduciendo la superficie de ataque interna
Nivel de prioridad	Crítico
Riesgos si este control no existe	Accesos innecesarios a sistemas críticos Escalada de privilegios Uso indebido de privilegios
Recomendaciones	Definir roles claramente diferenciados en función de las funciones laborales (operadores, técnicos, mantenimiento, proveedores, corporativos, administradores, etc...) y asignar los permisos y los accesos en base a los roles de cada uno
Referencia	

Identificador	CA-002
Control	Se separan las cuentas de usuario estándar de las privilegiadas
Por qué es importante	El uso de cuentas privilegiadas para tareas cotidianas aumenta el riesgo de comprometer sistemas críticos. Separar cuentas según su nivel de privilegio permite limitar el alcance de incidentes de seguridad y aplicar controles más estrictos cuando sea necesario
Nivel de prioridad	Crítico
Riesgos si este control no existe	Uso indebido de privilegios elevados Ejecución de comandos no autorizados Mayor impacto ante compromisos de cuentas de usuario
Recomendaciones	Definir y gestionar cuentas con diferentes niveles de acceso y limitar el uso de cuentas privilegiadas solo a tareas específicas
Referencia	

Identificador	CA-003
Control	Se requieren credenciales únicas y separadas para que los usuarios accedan a las redes OT e IT
Por qué es importante	Utilizar credenciales distintas para OT e IT impide que una credencial comprometida en una red pueda reutilizarse en otra, reduciendo el riesgo de movimiento lateral entre redes con distintos perfiles de exposición y criticidad
Nivel de prioridad	Crítico
Riesgos si este control no existe	Movimientos laterales entre los entornos IT y OT
Recomendaciones	Establecer credenciales diferenciadas para entornos IT y OT
Referencia	

Identificador	CA-004
Control	Se modifican las contraseñas por defecto en todos los sistemas IT/OT
Por qué es importante	Las contraseñas por defecto están documentadas públicamente, si no se cambian pueden ser utilizada por atacantes para acceder a sistemas críticos sin esfuerzo
Nivel de prioridad	Crítico
Riesgos si este control no existe	Accesos no autorizados a sistemas Compromisos de dispositivos como PLCs, SCADA, routers Escalada de privilegios
Recomendaciones	Cambiar todas las contraseñas por defecto inmediatamente después de la instalación y establecer políticas que impidan el uso de credenciales por defecto
Referencia	

Identificador	CA-005
Control	Se requiere una longitud mínima para las contraseñas
Por qué es importante	Las contraseñas cortas o simples son fácilmente vulnerables a ataques de fuerza bruta o diccionario. Establecer una longitud mínima es una de las formas más efectivas de fortalecer la autenticación
Nivel de prioridad	No crítico
Riesgos si este control no existe	Accesos no autorizados Vulnerabilidad frente a ataques automatizados Suplantación de identidad Compromisos de sistema críticos Robo de información
Recomendaciones	Establecer una longitud mínima de al menos 12 caracteres acompañada de requisitos de complejidad (mayúsculas, números, símbolos)
Referencia	

Identificador	CA-006
Control	Se requiere MFA, siempre que sea posible, para acceder remotamente a las redes OT e IT
Por qué es importante	Los accesos remotos son especialmente vulnerables, ya que se realizan desde ubicaciones no controladas. El uso de MFA añade una capa crítica de seguridad ante robos de credenciales o ataques de fuerza bruta
Nivel de prioridad	Crítico
Riesgos si este control no existe	Compromiso remoto de redes IT/OT Acceso con credenciales robadas Escalada de privilegios desde entorno externos
Recomendaciones	Habilitar MFA para todas las conexiones remotas
Referencia	

Identificador	CA-007
Control	Se aplica autenticación multifactor en las áreas críticas para garantizar un acceso seguro
Por qué es importante	La autenticación multifactor (MFA) reduce el riesgo de accesos no autorizados incluso cuando las contraseñas son comprometidas
Nivel de prioridad	Crítico
Riesgos si este control no existe	Accesos no autorizados con credenciales robadas Suplantación de identidad Acceso a sistemas críticos
Recomendaciones	Implementar MFA utilizando factores como contraseñas más un token físico o biometría para los accesos a redes OT, paneles de control, interfaces SCADA y sistemas administrativos críticos
Referencia	

Identificador	CA-008
Control	Se deshabilita inmediatamente el acceso a una cuenta o red cuando el acceso ya no es necesario debido a la jubilación, cambio de rol, u otros factores
Por qué es importante	Las cuentas activas sin uso representan un riesgo significativo, ya que pueden ser explotadas sin ser detectadas. Eliminar o desactivar accesos obsoletos previene accesos no autorizados y facilita el cumplimiento de políticas de seguridad
Nivel de prioridad	Crítico
Riesgos si este control no existe	Accesos no autorizados Falta de cumplimiento normativo Cuentas huérfanas que pueden ser utilizadas por atacantes
Recomendaciones	Implementar procedimientos automáticos o manuales para desactivar cuentas inmediatamente tras una baja laboral, cambio de funciones o finalización de un contrato
Referencia	

Identificador	CA-009
Control	Las estaciones de operación industrial (HMI, SCADA) requieren autenticaciones individuales y seguras
Por qué es importante	Las HMI y SCADA permiten el control directo de procesos industriales. Requerir autenticaciones individuales asegura que solo personal autorizado acceda y permite trazar quién realizó cada acción, reduciendo riesgos operativos y de seguridad
Nivel de prioridad	Crítico
Riesgos si este control no existe	Cambios no autorizados en procesos Manipulación de sistemas por personal no identificado
Recomendaciones	Configurar cuentas de usuario únicas con distintos niveles de acceso según el rol
Referencia	

Identificador	CA-010
Control	Existen controles de sesión que permiten finalizar sesiones inactivas, restringir el acceso a contenido no autorizado y prevenir conexiones a sitios web potencialmente maliciosos
Por qué es importante	Las sesiones abiertas e inactivas pueden ser aprovechadas por usuarios no autorizados para acceder a sitios maliciosos, descarga de malware, filtrar contenido, etc..
Nivel de prioridad	No crítico
Riesgos si este control no existe	Exposición a malware Propagación de malware Fuga o robo de información Violación de políticas de uso aceptable
Recomendaciones	Configurar el bloqueo o el cierre automático de sesiones tras un periodo de inactividad definido según el perfil de riesgo
Referencia	

Identificador	CA-011
Control	Existen controles de autenticación y validación de integridad en las comunicaciones con smart meters
Por qué es importante	La autenticación y la integridad en las comunicaciones con los Smart meters garantizan que los datos transmitidos no han sido modificados, ya que pueden ser objetivo de manipulación para alterar consumos o provocar errores en la facturación
Nivel de prioridad	No crítico
Riesgos si este control no existe	Fraude Pérdida de reputación
Recomendaciones	Utilizar protocolos seguros que incluyan autenticación mutua entre el smart meter y el sistema central y que la transmisión de datos esté protegida por mecanismos de validación de integridad como hashes
Referencia	

Identificador	CA-012
Control	Existe un sistema que centraliza la autenticación y la autorización de accesos mediante mecanismos como el inicio de sesión único (SSO)
Por qué es importante	Un sistema Single Sign-On (SSO) facilita la gestión de identidades, mejora la trazabilidad de accesos y permite aplicar políticas uniformes de seguridad y autenticación en toda la organización
Nivel de prioridad	No crítico
Riesgos si este control no existe	Gestión descentralizada de acceso Riesgo de cuentas con privilegios excesivos
Recomendaciones	Implementar soluciones de autenticación centralizada o sistema SSO
Referencia	

Identificador	CA-013
Control	Existen zonas protegidas a las que sólo puede acceder el personal autorizado mediante controles de entrada y procedimientos establecidos
Por qué es importante	Este control es importante porque limita el acceso físico a áreas críticas y asegura que solo el personal autorizado pueda acceder, evitando que actores maliciosos puedan manipular o desconectar sistemas, robar datos y sabotear la organización
Nivel de prioridad	Crítico
Riesgos si este control no existe	Acceso físico no autorizado a sistemas industriales Manipulación de equipos Robo de dispositivos
Recomendaciones	Definir zonas seguras dentro de la instalación y aplicar mecanismos de acceso físico controlado, registrando entradas y salidas
Referencia	

Identificador	CA-014
Control	Se registran y auditan periódicamente los accesos a los sistemas de control industrial
Por qué es importante	La auditoría de accesos permite detectar comportamientos anómalos, investigar incidentes de seguridad y verificar el cumplimiento de las políticas de control de acceso
Nivel de prioridad	Crítico
Riesgos si este control no existe	Actividades no autorizadas no detectadas Imposibilidad de rastrear incidentes Falta de evidencia para respuesta Falta de cumplimiento normativo
Recomendaciones	Configurar los sistemas industriales para registrar todos los accesos y usar herramientas de correlación de eventos para mantener los registros almacenados de forma segura
Referencia	

Identificador	CA-015
Control	Existe un marco de gestión que regula el acceso inalámbrico y de invitados, incluyendo su control, revisión y auditoría periódica
Por qué es importante	El acceso inalámbrico y de invitados representa un riesgo significativo si no está debidamente segmentado, autenticado y monitoreado. Una buena gestión evita que visitante y dispositivos externos comprometan la red interna o accedan a recursos no autorizados
Nivel de prioridad	No crítico
Riesgos si este control no existe	Accesos no autorizados Movimientos laterales desde la red de invitados Introducción de malware
Recomendaciones	Establecer SSID separados y segmentados para invitados, implementando autenticación diferenciada, control de duración del acceso y restricciones de tráfico. Desactivar automáticamente los accesos tras un tiempo determinado
Referencia	

Identificador	CA-016
Control	Existe un sistema de control de accesos que protege la documentación, los recursos críticos y las credenciales del sistema frente a accesos no autorizados
Por qué es importante	Es importante para prevenir fuga de información, sabotaje, espionaje industrial, explotación de vulnerabilidades
Nivel de prioridad	Crítico
Riesgos si este control no existe	Acceso interno no autorizado Robo de propiedad intelectual Exposición de datos sensible
Recomendaciones	Clasificar la documentación y restringir el acceso a personal autorizado mediante autenticación multifactor y registros de acceso
Referencia	

Protección de la Información

Estos controles evalúan las medidas implementadas para preservar la confidencialidad, integridad y disponibilidad de los datos operativos y de gestión, tanto en tránsito como en reposo. También se evalúan los mecanismos de respaldo y recuperación, como se clasifican los datos y su recuperación ante incidentes de seguridad.

Identificador	PI-001
Control	Existe un sistema de clasificación de la información que la categoriza en función de su criticidad y confidencialidad
Por qué es importante	Clasificar la información permite aplicar controles adecuados según el nivel de riesgo asociado a su pérdida, alteración o divulgación. Mejora la protección de datos sensibles y permite priorizar esfuerzos de seguridad
Nivel de prioridad	Crítico
Riesgos si este control no existe	Mayor exposición a uso indebido o acceso no controlado Dificultad para priorizar la protección en entornos controlados
Recomendaciones	Clasificar la documentación técnica, las configuraciones, las bases de datos, las credenciales, los planos de red
Referencia	

Identificador	PI-002
Control	Se utiliza cifrado eficaz para proteger la confidencialidad de los datos sensibles almacenados
Por qué es importante	El cifrado de datos en reposo previene el acceso no autorizado a información sensible en caso de pérdida, robo o acceso indebido a dispositivos de almacenamiento
Nivel de prioridad	Crítico
Riesgos si este control no existe	Acceso no autorizado a configuraciones de dispositivos, planos de red, credenciales, historiales de operación, etc. Riesgo de exfiltración de datos
Recomendaciones	Cifrar los discos duros de estaciones de trabajo y servidores donde se almacene información sensible. Hay que asegurar que las copias de seguridad estén cifradas y almacenadas de forma segura. Aplicar medidas compensatorias en dispositivos legacy
Referencia	

Identificador	PI-003
Control	Se implementan controles para garantizar la integridad de los datos operativos críticos
Por qué es importante	La integridad garantiza que los datos no hayan sido alterados de forma no autorizada. En entornos OT, una alteración de datos puede afectar decisiones operativas y comprometer la seguridad del proceso
Nivel de prioridad	Crítico
Riesgos si este control no existe	Modificación intencionada o accidental de parámetros críticos Alteración de registros históricos Pérdida de confidencialidad en la supervisión y control de procesos industriales
Recomendaciones	Implementar mecanismos de control de integridad en archivos y backups críticos. Configurar alertas ante cambios no autorizados. Habilitar el registro de eventos y auditar cambios regularmente. Aplicar medidas compensatorias en sistemas que no soporten estas funciones
Referencia	

Identificador	PI-004
Control	Se utiliza cifrado eficaz para proteger la confidencialidad de los datos en tránsito
Por qué es importante	El cifrado protege la información durante su transmisión entre dispositivos o redes, evitando que pueda ser interceptada o manipulada por atacantes
Nivel de prioridad	Crítico
Riesgos si este control no existe	Interceptación de datos Robo de credenciales Manipulación de comandos Manipulación de datos de procesos
Recomendaciones	Implementar protocolos de cifrado robustos. Evitar el uso de protocolos obsoletos como Telnet o FTP. Siempre que sea posible, utilizar protocolos industriales modernos con cifrado nativo (como OPC UA con TLS). En redes inseguras o remotas, encapsular las comunicaciones OT dentro de túneles VPN. En caso de dispositivos legacy, aplicar controles compensatorios.
Referencia	

Identificador	PI-005
Control	Las comunicaciones inalámbricas se cifran de forma adecuada para proteger la información en tránsito
Por qué es importante	El cifrado protege la confidencialidad e integridad de la información transmitida, evitando ataque de tipo Man-in-the-Middle
Nivel de prioridad	Crítico
Riesgos si este control no existe	Interceptación de tráfico de datos Exposición a técnicas de spoofing o rogue AP
Recomendaciones	Configurar todos los puntos de acceso inalámbrico con cifrado robusto (WPA2 como mínimo). Evitar el uso de WEP y redes abiertas. Usar listas de control de acceso (MAC filtering). Segmentar el tráfico inalámbrico
Referencia	

Identificador	PI-006
Control	Las VPN utilizadas entre redes no confiables y la red de control aplican cifrado seguro con estándares como Ipsec, SSL o SSH.
Por qué es importante	Las redes privadas virtuales (VPN) permiten conectar sitios remotos o acceder a redes de control desde el exterior. Si no se utilizan protocolos seguros, estas conexiones pueden ser interceptadas o utilizadas como puerta de entrada por atacantes
Nivel de prioridad	Crítico
Riesgos si este control no existe	Exposición de credenciales, comandos y datos operativos durante la transmisión Uso indebido de túneles inseguros para el acceso a la red OT Riesgo de acceso desde redes externas o IT a redes críticas
Recomendaciones	Hay que asegurar que todas las VPNs utilizadas utilicen protocolos de cifrado robusto. Evitar el uso de PPTP. Limitar el acceso VPN a direcciones IP y usuarios autorizados. Emplear autenticación multifactor. Registrar todas las conexiones. Implementar segmentación entre redes
Referencia	

Identificador	PI-007
Control	Se cifran o protegen las comunicaciones entre dispositivos industriales (por ejemplo, PLC a SCADA) siempre que sea posible
Por qué es importante	Las comunicaciones entre dispositivos OT como PLCs, RTUs y SCADA suelen ser directas y no cifradas, lo que las hace vulnerables a ataques de interceptación, manipulación o suplantación. Proteger estas comunicaciones preserva la integridad y confidencialidad del proceso industrial
Nivel de prioridad	Crítico
Riesgos si este control no existe	Interceptación de comandos Manipulación de procesos Pérdida de integridad operacional Falsificación de señales
Recomendaciones	Utilizar versiones seguras de protocolos industriales (donde sea posible). Aplicar medidas compensatorias en esos dispositivos legacy sin capacidad de cifrado
Referencia	

Identificador	PI-008
Control	Existen mecanismos para asegurar la disponibilidad y recuperación de los datos críticos en caso de incidente.
Por qué es importante	Es importante de cara a una recuperación ante fallos, ataques o desastres
Nivel de prioridad	Crítico
Riesgos si este control no existe	Pérdida de datos críticos Interrupción de operaciones Imposibilidad de reprimir configuraciones de sistemas SCADA o PLCs Mayor tiempo de inactividad tras un incidente
Recomendaciones	Establecer un plan de respaldo y recuperación que cubra datos operativos, configuraciones de sistemas y archivos críticos. Realizar copias de seguridad frecuentes y almacenarlas en ubicaciones seguras. Verificar regularmente que los backups sean funcionales mediante simulacros de restauración
Referencia	

Identificador	PI-009
Control	Se realizan copias de seguridad de los sistemas y elementos críticos para la operación (configuraciones de red, lógica de PLC, documentación técnica, planos de ingeniería, registros de personal). Estas copias se almacenan en ubicaciones separadas de los sistemas de origen y se prueban de manera periódica para garantizar su validez
Por qué es importante	Las copias de seguridad garantizan la capacidad de restaurar sistemas críticos y retomar operaciones ante incidentes como fallos técnicos, ciberataques o errores humanos. Son esenciales para asegurar la continuidad del servicio
Nivel de prioridad	Crítico
Riesgos si este control no existe	Pérdida irreversible de configuraciones o datos críticos. Imposibilidad de restaurar lógica de control en PLCs o SCADA. Falta de cumplimiento normativo
Recomendaciones	Establecer un calendario regular de copias de seguridad (diarias/semanales según criticidad), incluyendo configuraciones de red, lógica de control de PLCs, procesos, datos históricos de operación
Referencia	

Seguridad Física

La seguridad física protege los activos críticos frente a accesos no autorizados o manipulaciones no autorizadas. La seguridad física es un componente fundamental en entornos como el sector del agua, ya que muchos dispositivos o sistemas pueden estar ubicados en zonas rurales remotas y estar desprotegidos.

Los siguientes controles evalúan la presencia de medidas físicas para proteger instalaciones, instalaciones remotas, sensores, tanques, estaciones de bombeo, servidores, puntos de entrada a sistemas críticos.

Identificador	SF-001
Control	Se garantiza la separación física entre las zonas logísticas y las áreas críticas de los sistemas OT
Por qué es importante	Las zonas de logística, carga, recepción o correo suelen tener un alto tránsito de personas, incluidos externos. Si no están físicamente separadas de áreas sensibles, pueden ser puntos de entrada para accesos no autorizados, robo de equipos o inserción de dispositivos maliciosos
Nivel de prioridad	Crítico
Riesgos si este control no existe	Acceso físico no autorizado a áreas críticas Instalación de hardware malicioso Robo de equipos de red o servidores Interrupción de operaciones por sabotaje físico
Recomendaciones	Hay que asegurar que las salas estén separadas físicamente de las salas de servidores, centros de control o redes OT. Utilizar puertas con cierre restringido. Utilizar control de acceso físico. Utilizar videovigilancia y supervisión de visitantes o proveedores. Minimizar el acceso innecesario al personal externo a zonas críticas
Referencia	

Identificador	SF-002
Control	Existe un perímetro de seguridad establecido para acceder a las instalaciones principales
Por qué es importante	Un perímetro de seguridad bien definido permite detectar y disuadir accesos no autorizados antes de que se acerquen a áreas sensibles. Es una primera barrera clave para la protección de activos críticos de OT/T
Nivel de prioridad	Crítico
Riesgos si este control no existe	Accesos sin controles a instalaciones críticas Riesgo de sabotaje físico Robo de equipamiento Inserción de hardware malicioso
Recomendaciones	Establecer y mantener un perímetro físico con rejas, vallas, muros, que delimite las instalaciones operativas principales. Establecer controles de acceso físicos en los puntos de entrada (guardias, tarjetas de identificación, sistemas biométricos). Establecer vigilancia
Referencia	

Identificador	SF-003
Control	Existe un perímetro de seguridad adecuado para proteger dispositivos o instalaciones remotas
Por qué es importante	Las instalaciones remotas suelen ser más vulnerables al acceso no autorizado debido a su ubicación aislada. Establecer un perímetro físico reduce significativamente los riesgos de sabotaje, manipulación de equipos o robo
Nivel de prioridad	Crítico
Riesgos si este control no existe	Acceso físico directo a sensores, PLCs, sistemas de comunicación Riesgo de desconexión de dispositivos Manipulación de procesos Robo Sabotaje de infraestructura
Recomendaciones	Implementar barreras físicas en las instalaciones remotas. Instalar cámaras o detección de intrusión cuando sea posible
Referencia	

Identificador	SF-004
Control	Los tanques intermedios de agua cuentan con controles de acceso físico y medidas de protección (cercas, alarmas o sensores)
Por qué es importante	Los tanques intermedios forman parte del sistema de almacenamiento y regulación del agua. Si no están protegidos adecuadamente, pueden ser vulnerables a accesos no autorizados, sabotaje físico o contaminación intencionada. Incorporar mecanismos de detección temprana ayuda a prevenir incidentes y permite una respuesta rápida
Nivel de prioridad	Crítico
Riesgos si este control no existe	Riesgo de acceso no autorizado a componentes críticos del sistema de distribución, manipulación de válvulas o sensores, interrupción del suministro Amenazas a la salud pública
Recomendaciones	Implementar sensores de apertura y cámaras para monitoreo remoto. Implementar vallas que restrinjan el acceso directo a los tanques en zonas rurales, implementar sensores de movimiento y sistemas de alarma
Referencia	

Identificador	SF-005
Control	Existe monitorización remota de los tanques intermedios (nivel de agua, aperturas no autorizadas)
Por qué es importante	La monitorización remota permite detectar a tiempo anomalías como caídas en el nivel de agua, aperturas indebidas o accesos no autorizados, especialmente en ubicaciones aisladas. Es importante para prevenir interrupciones o sabotajes
Nivel de prioridad	Crítico
Riesgos si este control no existe	Manipulación. Sabotaje. Interrupción del suministro
Recomendaciones	Instalar sensores para la monitorización remota
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SF-006
Control	Existen medidas de seguridad física para smart meters utilizados en la red.
Por qué es importante	Los Smart meters suelen estar instalado en exteriores y están expuestos a manipulación física, accesos no autorizado y vandalismo. Proteger los Smart meters ayuda a reducir el riesgo de falsificación de lecturas o interrupciones de servicios. También podrían ser usado como vectores de ataque hacia la red de control
Nivel de prioridad	No crítico
Riesgos si este control no existe	Fraude en facturación Alteración de datos de consumo Uso como vector de ataque hacia la red de control
Recomendaciones	Utilizar cajas cerradas para proteger los Smart meters. Aplicar dispositivos anti-manipulación. Implementar sensores que alerten ante manipulación
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SF-007
Control	Existe un sistema de monitorización del acceso a las instalaciones (registros, cámaras, sensores)
Por qué es importante	La monitorización permite actuar contra intrusiones y responder ante incidentes
Nivel de prioridad	Crítico
Riesgos si este control no existe	Accesos físicos no detectados Robo o manipulación no autorizada
Recomendaciones	Instalar sistemas de videovigilancia en accesos principales y zonas críticas y mantener un registro de eventos
Referencia	NIST SP 800-53 CA-7, PE-6, PE-20, AC-2, AU-12, AU-13, CA-7, CM-10, CM-11

Identificador	SF-008
Control	Se prohíbe la conexión de hardware no autorizado (por ejemplo, unidades USB, medios extraíbles, ordenadores portátiles traídos por otros) a los activos OT e IT
Por qué es importante	El hardware no autorizado puede contener malware, ejecutar código no autorizado o abrir backdoor hacia la red interna, poniendo en riesgo la operación de procesos críticos
Nivel de prioridad	Crítico
Riesgos si este control no existe	Introducción de malware Acceso no autorizado Ransomware Interrupciones operativas
Recomendaciones	Deshabilitar puertos USB o restringir su uso mediante software de gestión. Implementar políticas estrictas que prohíban el uso de dispositivos externos no autorizados
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SF-009
Control	Existe seguridad física y procedimientos que protegen los equipos frente a amenazas ambientales, condiciones adversas y accesos no autorizados
Por qué es importante	La humedad, el polvo, el calor extremo, las vibraciones, las inundaciones, los incendios pueden afectar el funcionamiento de los sistemas IT/OT, comprometiendo la seguridad del proceso y derivando en interrupciones del servicio
Nivel de prioridad	Crítico
Riesgos si este control no existe	Fallos de hardware Interrupciones operativas Riesgos para la seguridad del personal
Recomendaciones	Ubicar los dispositivos en entornos controlados. Implementar climatización adecuada. Implementar UPS. Implementar protección contra sobretensión. Implementar sensores ambientales.
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SF-010
Control	Existen alarmas de intrusión física conectadas a un centro de control operativo o sistema de respuesta
Por qué es importante	Es importante tener una conexión directa con un centro de control para actuar ante intrusiones, minimizando riesgos y reduciendo tiempos de exposición
Nivel de prioridad	Crítico
Riesgos si este control no existe	Intrusiones no detectadas en tiempo real Retraso en la respuesta ante incidentes
Recomendaciones	Implementar sensores de intrusión con el centro de control y sistema de gestión de eventos
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SF-011
Control	Se han implementado medidas específicas para proteger infraestructuras críticas contra sabotaje físico (por ejemplo, blindaje de tuberías, estaciones de bombeo)
Por qué es importante	Las infraestructuras críticas del ciclo del agua, como estaciones de bombeo o redes de distribución, pueden ser blanco de sabotajes intencionados. Protegerlas físicamente garantiza la continuidad del servicio, la seguridad pública y minimiza los impactos operativos en caso de ataque
Nivel de prioridad	Crítico
Riesgos si este control no existe	Riesgo de interrupción de suministro Exposición a vandalismo o sabotaje
Recomendaciones	Implementar blindaje físico para los activos más críticos como estaciones de bombeo, válvulas principales, tuberías troncales
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SF-012
Control	Se realizan inspecciones regulares de los sensores de acuíferos alimentados por baterías para detectar fallos, manipulaciones o falta de lecturas
Por qué es importante	Los sensores de acuíferos alimentados por baterías suelen estar instalados en ubicaciones remotas y sin supervisión continua. La falta de inspección puede derivar en lecturas erróneas, datos faltantes, sabotaje no detectado o fallos prolongados que afecten la gestión de recursos hídricos
Nivel de prioridad	No crítico
Riesgos si este control no existe	Fallos en la recogida de datos críticos Manipulaciones no detectadas Degradación de la calidad de servicio
Recomendaciones	Realizar inspecciones regulares de los sensores y verificar la integridad física del dispositivo
Referencia	Taller CWP

Identificador	SF-013
Control	Existe un plan de reposición y actualización tecnológica de sensores en zonas remotas
Por qué es importante	Los sensores remotos tienen un ciclo de vida limitado, es importante mantenerlos actualizado para garantizar continuidad operativa, garantizar la integridad de los datos y tener una mejor resistencia frente a nuevas amenazas
Nivel de prioridad	No crítico
Riesgos si este control no existe	Firmware desactualizado Fallos de recopilación de datos Fallos operativos
Recomendaciones	Mantener un plan de reposición periódica de sensores críticos en zona remotas, priorizando los sensores que llevan mayor exposición
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SF-014
Control	Se aplican controles de acceso temporal para contratistas o visitantes en zonas críticas
Por qué es importante	El acceso no controlado de personal externo a zonas críticas puede facilitar actos de sabotaje, robo de información, o exposición accidental a componentes sensibles. Este control es importante para reducir estos riesgos
Nivel de prioridad	Crítico
Riesgos si este control no existe	Acceso no autorizado a sistemas críticos Introducción de malware Sabotaje accidental o intencionado
Recomendaciones	Implementar sistemas de acceso físico temporales. Implementar acompañamiento obligatorio para los visitantes. Registrar entradas y salidas. Establecer procedimientos de autorización previa y validación de identidad
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	SF-015
Control	Existe un plan de respuesta ante incidentes de intrusión física, daño o sabotaje en la infraestructura
Por qué es importante	Detectar una intrusión o sabotaje no es suficiente si no existe una capacidad clara y rápida de respuesta. Un plan de actuación permite minimizar el impacto, proteger al personal, preservar evidencias y restaurar operaciones de forma ordenada
Nivel de prioridad	Crítico
Riesgos si este control no existe	Mayor impacto del daño Retraso en la respuesta a incidentes Falta de cumplimientos legales
Recomendaciones	Establecer un plan de respuesta ante incidente físicos
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Formación

La formación en ciberseguridad asegura que los empleados o terceras partes que están involucradas con las operaciones de la planta comprendan los riesgos a los que están expuestos y actúen de forma adecuada para prevenir incidentes.

Estos controles verifican si se han implementado acciones formativas para mejorar el conocimiento en ciberseguridad de los empleados.

Identificador	FO-001
Control	Existe un programa de formación que capacita al personal para reconocer incidentes, aplicar las políticas y los procedimientos de seguridad establecidos
Por qué es importante	Para asegurarse que todo el personal esté preparado a reconocer y reaccionar ante incidentes de seguridad, de acuerdo con las políticas y procedimientos establecidos
Nivel de prioridad	Crítico
Riesgos si este control no existe	Falta de conciencia sobre las amenazas de seguridad Retrasos en la respuesta a incidentes Incidentes no detectados o gestionados incorrectamente
Recomendaciones	Implementar un programa de concienciación
Referencia	NIST SP 800-82 Rev. 3, NIST 800-53, IEC62443, AWWA Cybersecurity Guidance

Identificador	FO-002
Control	Se proporciona formación específica sobre ciberseguridad adaptada al rol de cada puesto de trabajo
Por qué es importante	Permite que cada empleado tenga una formación de ciberseguridad adaptada al rol que tiene dentro de la organización
Nivel de prioridad	Crítico
Riesgos si este control no existe	Desconocimiento de las amenazas específicas relacionadas con su trabajo Vulnerabilidades operativas. Falta de cumplimiento normativo
Recomendaciones	Brindar formación específica sobre ciberseguridad adaptada al rol de cada puesto de trabajo
Referencia	NIST SP 800-53 AT-3, PM-13

Identificador	FO-003
Control	Se proporciona formación específica sobre respuesta a incidentes a empleados, contratistas y usuarios de terceros
Por qué es importante	Ayuda a preparar a todo el personal, incluidos los contratistas y usuarios de terceros, para actuar de manera efectiva ante un incidente de seguridad, asegurando que se sigan los procedimientos correctos y que la respuesta sea rápida y organizada
Nivel de prioridad	No crítico
Riesgos si este control no existe	Respuestas lentas o descoordinadas Impacto mayor en la continuidad del negocio Falta de cumplimiento normativo
Recomendaciones	Desarrollar y proporcionar formación específica sobre respuesta a incidentes a todos los empleados, contratistas y usuarios de terceros que tengan acceso a los sistemas críticos
Referencia	AT-2 AWWA, NIST SP 800-53 AT-3, PM-13

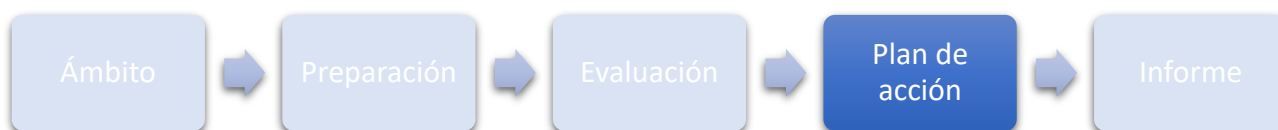
Identificador	FO-004
Control	Se realiza formación anual de concienciación sobre ciberseguridad para todo el personal de la instalación que cubre conceptos básicos de ciberseguridad
Por qué es importante	La falta de concienciación incrementa la probabilidad de errores, accesos indebidos o infecciones por malware. En instalaciones de agua, donde coexisten entornos TI y OT, el personal debe entender los riesgos que afectan tanto a sistemas informáticos como a los sistemas de control industrial, así como las buenas prácticas de comportamiento seguro. La formación continua fortalece la cultura de ciberseguridad, reduce los incidentes y mejora la capacidad de respuesta
Nivel de prioridad	Crítico
Riesgos si este control no existe	Mayor exposición a ataques de ingeniería social y phishing. Manipulación accidental o intencionada de sistemas OT. Pérdida de integridad y disponibilidad de los servicios de agua. Incapacidad de identificar comportamientos anómalos o incidentes en etapas tempranas
Recomendaciones	Diseñar e implementar un programa de formación básica obligatoria en ciberseguridad, adaptado al sector agua y las funciones de cada rol (operadores OT, personal administrativo, técnicos, etc.). Evaluar el nivel de comprensión mediante pruebas o simulaciones (por ejemplo, campañas de phishing controladas)
Referencia	NIST SP 800-53 AT-2, PM-13, PM-14

Identificador	FO-005
Control	Recibe formación específica en ciberseguridad el personal que opera y mantiene SCADA, PLC y otros dispositivos de control industrial
Descripción	Es importante que el personal técnico que opera o mantiene sistemas de control industrial (SCADA, PLC, RTU...) reciba formación especializada en ciberseguridad, centrada en los riesgos, amenazas y vulnerabilidades específica del entorno OT para poder identificar, prevenir y responder a amenazas que afecten a los sistemas de control
Nivel de prioridad	Crítico
Riesgos si este control no existe	Mayor exposición a ataques dirigidos a dispositivos vulnerables o mal configurados Manejo incorrecto o inseguro de sistemas críticos
Recomendaciones	Brindar formación especializada en ciberseguridad OT dirigida a operadores de la planta
Referencia	NIST SP 800-53 AT-3, PM-13

Identificador	FO-006
Control	Se capacita al personal sobre respuesta específica a incidentes que afecten la operación de infraestructuras críticas de agua
Por qué es importante	Este control verifica que el personal responsable de operar, mantener o supervisar infraestructuras críticas de agua (plantas potabilizadoras, estaciones de bombeo, sistemas SCADA, redes de distribución, tratamiento de aguas residuales) reciba una formación especializada para responder a incidentes que comprometan la seguridad del suministro de agua
Nivel de prioridad	Crítico
Riesgos si este control no existe	Contaminación accidental o intencional del agua sin detección o reacción a tiempo Daño reputacional Falta de cumplimiento normativo Respuesta a incidentes no adecuada
Recomendaciones	Desarrollar un programa específico de formación en respuesta a incidentes para infraestructuras de agua
Referencia	NIST SP 800-53 AT-3, PM-13

Identificador	FO-007
Control	Se realizan simulacros prácticos o ejercicios de respuesta a incidentes cibernéticos (ejemplo Cyberrange)
Por qué es importante	Este control verifica que la organización lleva a cabo simulacros diseñados para probar la eficacia de sus planes de respuesta a ciber incidentes y validar que planes y procedimientos funcionan adecuadamente
Nivel de prioridad	Crítico
Riesgos si este control no existe	Falta de preparación del personal para gestionar incidentes reales Mayor impacto ante un ciberataque Falta de cumplimiento normativo
Recomendaciones	Establecer un plan anual de ejercicios y simulacros
Referencia	Taller CWP

Plan de acción



El objetivo del plan de acción es mitigar los riesgos identificados en la fase de Evaluación a través de la implementación de las medidas correctivas recomendadas.

Es una fase obligatoria, que sigue a la Evaluación y tiene como propósito, desde el punto de vista metodológico, priorizar las vulnerabilidades/debilidades detectadas en función de su impacto sobre la continuidad del servicio y la seguridad de las personas y los activos, traducir los resultados de la fase de Evaluación en acciones concretas y asignar responsables, recursos (económicos, técnicos y de personal) y fechas límite para cada acción.

Cada Plan de acción, independientemente de la herramienta utilizada, debe contener:

- Medidas correctivas o recomendaciones para cada debilidad o vulnerabilidad detectada
- Nivel de prioridad de cada acción
- Responsable asignado para mitigar la vulnerabilidad o implementar la acción correctiva
- Fechas estimadas de mitigación, 30 días (prioridad Muy alta), 90 días (prioridad Alta), 180 días (prioridad Media), 365 días (prioridad Baja)

La metodología no impone herramientas específicas. Cada organización puede desarrollar su plan de acción utilizando los medios que considere más adecuados, pero respetando siempre los principios de trazabilidad y priorización de las acciones.

Las recomendaciones presentadas en este documento son medidas destinadas a reducir riesgos, y están alineadas con el NIST CSF y el NIST 800-82.

Para facilitar la aplicación práctica de esta fase, la herramienta Excel asociada, implementa la lógica del plan de acción de forma automatizada y estructurada.

  									
Diagnóstico de Ciberseguridad para Infraestructuras de Agua									
Plan de acción El objetivo es priorizar y definir las medidas correctivas a implementar para reducir las vulnerabilidades detectadas									
ID	Área	Resultado	Recomendaciones	Prioridad	Fecha límite sugerida	Estado	Responsable	Fecha cierre real	Observaciones
GO-001	Gobernanza	2 - Básico	Elaborar y mantener un inventario centralizado de todos los dispositivos IT/OT de la organización	Alta (acción necesaria)	04/10/2025	Completado	García	04/10/2025	se ha mejorado el inventario según las indicaciones de la IEC62443
GO-004	Gobernanza	2 - Básico	Crear un repositorio estructurado y establecer un responsable para el documento de revisión y el documento de actualización. Formar al personal sobre cómo consultar los documentos	Baja o Solo seguimiento	06/07/2026	Completado	Lopez	06/09/2025	se ha creado el repositorio y se ha formado el personal
GO-005	Gobernanza	2 - Básico	Aplicar el principio de mínimos privilegios y acceso basado en roles. Establecer un procedimiento de evaluación y aprobación de riesgos para todas las solicitudes de acceso a sistemas críticos.	Media (mejora programada)	02/01/2026	Completado	Sanchez	01/01/2026	se ha aplicado el principio de privilegios mínimos
GO-006	Gobernanza	2 - Básico	Crear un registro interno donde se identifiquen todas las normativas relevantes para la organización. Asignar un responsable de su seguimiento y actualización	Media (mejora programada)	02/01/2026	Completado	Ramirez	01/12/2025	se han identificado todas las normativas relevantes

Ilustración 8. Ejemplo Plan de acción

La herramienta identifica de forma automática los controles con menor nivel de implementación (*Inexistente, Parcial, Básico*), basándose en los resultados de la Evaluación. A partir de estos datos, la herramienta genera recomendaciones generales para cada control afectado y asigna un nivel de prioridad a las acciones correctivas, considerando el impacto potencial que la ausencia o deficiencia del control puede tener sobre la salud pública y los sistemas de control y la criticidad del control (*Crítico o No crítico*).

En función del nivel de prioridad asignado, la herramienta propone plazos orientativos (*Muy alta=30 días, Alta=90 días, Media=180 días, Baja=365 días*) para la mitigación de cada debilidad detectada.

El usuario también puede añadir información adicional como los responsables asignados para llevar a cabo las tareas y las fechas de cierre real, así como comentarios adicionales relevantes.

Esta hoja permite obtener una visión global del **Plan de acción** y ayuda a tener un seguimiento de las acciones y de la toma de decisiones.

Una vez ejecutado el **Plan de acción**, la organización dispondrá de una visión más clara de su postura de ciberseguridad. Este proceso es la base que sirve para evolucionar progresivamente hacia evaluaciones de ciberseguridad de mayor complejidad y profundidad. El Plan de acción permite a las organizaciones pasar desde un nivel inicial nulo, básico o reactivo hacia una postura más proactiva.

En la pestaña **Dashboard**, la sección Situación actual, permite visualizar de forma compacta el avance del Plan de acción, facilitando el seguimiento de las medidas implementadas.

El panel tiene en la parte alta los indicadores globales y una tabla de evolución del cumplimiento por áreas. También es posible visualizar un gráfico que muestra las prioridades del plan de acción.

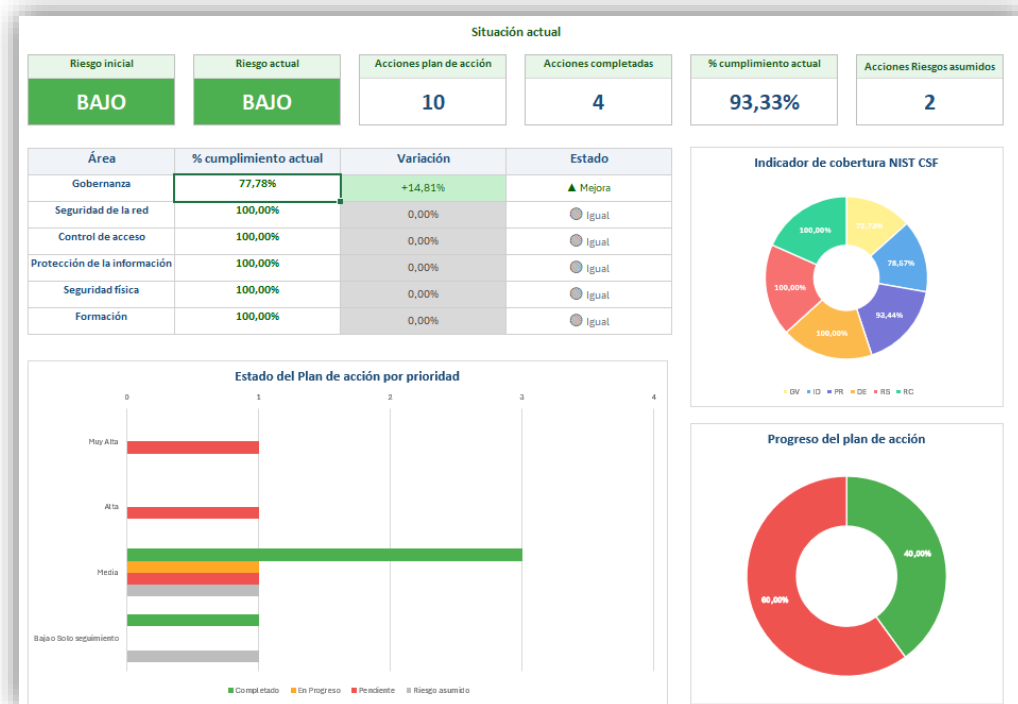


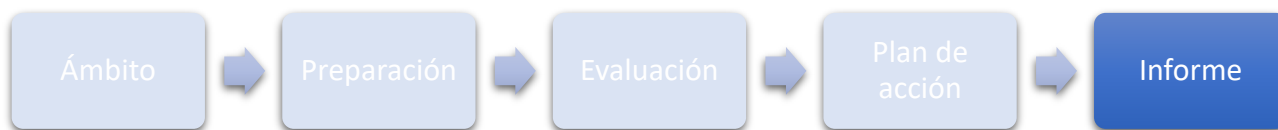
Ilustración 9. Dashboard de la situación actual que muestra los avances del plan de acción

A continuación, se describe cada uno de los indicadores:

- **Riesgo inicial:** es el nivel de riesgo inicial estimado tras la Evaluación inicial, antes de ejecutar el Plan de acción. Representa la situación de partida
- **Riesgo actual:** es el nivel de riesgo actualizado, considerando las acciones que se van completando. Permite medir la reducción de riesgos tras la implementación del Plan de acción
- **Acciones plan de acción:** la cantidad total de acciones a realizar que genera la herramienta tras la Evaluación y definidas en el Plan de acción. Estas acciones se validan por la organización con la asignación de responsables y con el estado (Completado, En progreso, Pendiente, Riesgo asumido)
- **Acciones completadas:** el número de acciones que se están implementando o se han implementados
- **% cumplimiento actual:** porcentaje global de cumplimiento actual, actualizado en función del progreso del Plan de acción
- **Acciones riesgos asumidos:** la cantidad de acciones que se han clasificado como riesgo asumido y no se mitigarán por decisión de la organización
- **Tabla de cumplimiento por área:** muestra el porcentaje actual de cumplimiento en cada área, la variación respecto a la Evaluación inicial y el estado general (Mejora, Empeora, Igual).

- **Indicador de cobertura NIST CSF:** representa el nivel de cobertura alcanzado en cada una de las funciones del NIST CSF
- **Estado del plan de acción por prioridad:** muestra el estado actual de las acciones, clasificado por prioridad, ayudando a identificar cuantas acciones críticas siguen pendientes
- **Progreso del plan de acción:** representa el porcentaje global de acciones completadas frente a las pendientes

Informe



El Informe es la fase final de la metodología y constituye el documento que consolida los hallazgos, resultados y recomendaciones del auto diagnóstico de ciberseguridad.

El objetivo del Informe es comunicar de forma clara el estado de la ciberseguridad de la organización y facilitar la comprensión de los resultados, tanto para perfiles técnicos como para la alta dirección, además de documentar todo el diagnóstico.

Desde el punto de vista metodológico, el informe debe incluir al menos los siguientes apartados:

- **Datos generales del diagnóstico**, nombre de la instalación, fecha, sistemas auditados, etc.
- **Resumen ejecutivo**, dirigido a perfiles directivos, debe centrarse en los hallazgos más relevantes y el nivel de riesgo identificado. Debe permitir comprender el impacto potencial de los riesgos sin necesidad de conocimientos técnicos avanzados
- **Estado actual**, donde se describe de forma objetiva la situación de la organización, basándose en los resultados de la Evaluación inicial

En el contexto de la guía práctica, la herramienta Excel asociada permite generar de forma automatizada un Informe estructurado que incluye:

- **Datos generales del diagnóstico**, identificación de la instalación, fecha del diagnóstico, responsable designado
- **Resumen ejecutivo**, que incluye un texto con el nivel de cumplimiento global, nivel de riesgo, el número de controles inexistentes
- **Objetivo y alcance del diagnóstico**, donde se detalla el sistema evaluado
- **Vista general de resultados**, que comprende gráficos de cumplimiento inicial por área y de la distribución de la madurez de los controles
- **Resumen de hallazgos**, con riesgo inicial, cumplimiento general, priorización de los controles evaluados según su criticidad y números de controles inexistentes por área
- **Recomendaciones**, un listado de acciones correctivas con su prioridad y área correspondiente

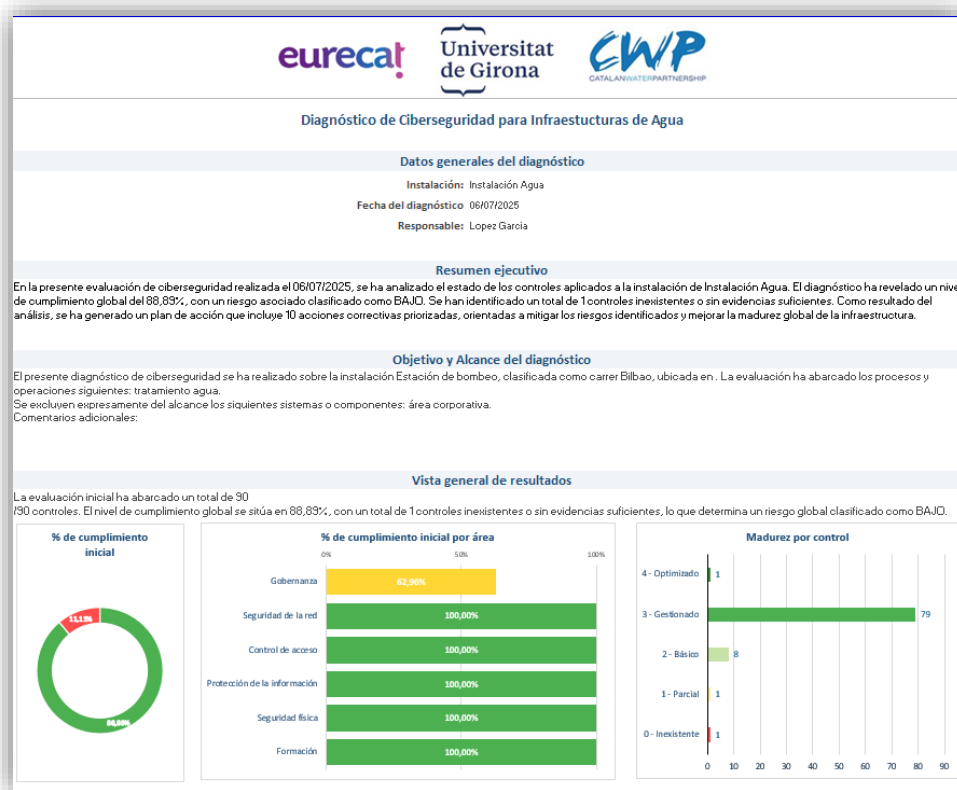


Ilustración 10. Ejemplo de Informe auto generado

El ejemplo práctico recomendado sigue estos pasos:

Generación automática del Informe	- La herramienta recopila los datos de Ámbito, Evaluación y Plan de acción - Se generan los indicadores y gráficos predefinidos
Personalización del informe	El usuario puede añadir comentarios o información complementaria
Presentación y validación	El informe se valida y se presenta al equipo técnico y la dirección

4. Casos de estudio

Esta sección presenta tres casos de estudio relevantes para el sector del agua desarrollados por Eurecat.

Los casos seleccionados representan diagnósticos realizados a PYMES responsables del ciclo de agua: una empresa de gestión integral del ciclo de agua, una empresa de tratamiento de agua y una empresa de distribución de agua.

Estos ejemplos ilustran cómo puede aplicarse de forma práctica la metodología de diagnóstico propuesta y los beneficios obtenidos. Cada sección incluye una descripción general del proyecto, las fases realizadas, los principales hallazgos detectados y las recomendaciones formuladas para mejorar la postura de ciberseguridad de la organización. Además, se propone una sección de lecciones aprendidas que sintetizan los aspectos clave del diagnóstico.

Por motivos de confidencialidad, toda la información sensible ha sido anonimizada y no es posible identificar a las organizaciones de los casos de estudio a partir de los datos presentados.

4.1. Caso de estudio 1 - Empresa de gestión integral del ciclo de agua

Este caso de estudio muestra un proyecto de ciber diagnóstico aplicado a una empresa que se ocupa de la gestión integral del ciclo de agua. El objetivo del diagnóstico fue evaluar su postura de ciber seguridad y proponer acciones de mejora.

El proyecto se realizó en varias fases.

La primera fase consistió en una fase de definición o alcance (**ámbito**) del sistema a evaluar. Se determinó el perímetro y los activos críticos a evaluar, abarcando tanto la red corporativa como la red industrial y la conexión entre ellas.

A continuación, se desarrolló una fase de **preparación**, donde se realizó una evaluación preliminar de la seguridad de la infraestructura recopilando toda la documentación existente: topologías de red, mapas de dispositivos, inventarios, máquina virtual que replicaba sistemas de control y que se utilizaba para pruebas.

Esta fase incluyó varias reuniones y sesiones de trabajo con los equipos técnicos de la empresa en objeto para validar la información recopilada, lograr una mejor comprensión del entorno y tener así una foto inicial de la infraestructura necesaria para realizar las fases siguientes.

Luego se realizó una fase de **evaluación**, donde se efectuó un análisis de los protocolos y tecnologías utilizadas. Se identificaron aquellos inseguros y aquellos vulnerables debido a configuraciones incorrectas. Además, se detallaron los servicios y puertos accesibles desde internet que podían representar vectores de entrada para un atacante, identificados consultando fuentes públicas. Posteriormente, se analizó el inventario de hardware proporcionado por la empresa, evaluando cada dispositivo para determinar su posible afectación por vulnerabilidades conocidas. Finalmente, se

desarrolló un caso práctico, que simulaba cómo un atacante podría comprometer la red OT basándose únicamente en la información pública disponible.

Se identificó que, a través de servicios como WHOIS, se podía recabar información importante que permitía realizar un reconocimiento del entorno.

Se detectaron puertos abiertos y servicios innecesarios expuestos a internet **(SR-010, Se garantiza que los activos conectados a la Internet pública no exponen servicios explotables innecesarios)** y páginas de administración accesibles sin mecanismos de protección como filtrado IP o VPN **(PI-006 - Las VPN utilizadas aplican estándares de cifrados seguros como IPsec, SSL o SSH para proteger comunicaciones entre redes no seguras y la red de control)**.

En la red interna se comprobó que la mayoría de los protocolos utilizados no cifraban las comunicaciones **(PI-004, Se utiliza cifrado eficaz para proteger la confidencialidad de los datos en tránsito)** lo que permitiría a un atacante interceptar tráfico, extraer credenciales y realizar movimientos laterales. También se encontraron dispositivos legacy y sin soporte por parte del fabricante **(SR-014, Se ha identificado y documentado la presencia de dispositivos OT legacy que no reciben actualizaciones de seguridad y se han implementado medidas de seguridad compensatorias para mitigar los riesgos asociados)**.

Durante el diagnóstico también se llevaron a cabo simulaciones de phishing, las cuales pusieron en evidencia la necesidad de implementar un programa o una formación de ciberseguridad **(FO-001, Existe un programa de formación que capacita al personal para reconocer incidentes, aplicar las políticas y los procedimientos de seguridad establecidos)**.

En fase posterior se realizó un análisis de la segmentación de la red desde diferentes puntos **(SR-005, Se aplican políticas estrictas de microsegmentación de red para separar dispositivos críticos OT de otros dispositivos IT o IloT)** : conexión con cable Ethernet en la sede DN, conexión vía WIFI en la sede de DN y conexión VPN desde las oficinas; luego se identificaron los puntos de interconexión entre la red IT y la red OT, distinguiendo entre la parte de aguas residuales y la parte de agua potable; se estudiaron los accesos remotos tanto de proveedores como de empleados de la compañía; se analizaron a nivel de seguridad las tecnologías inalámbricas utilizadas en la compañía.

Con este análisis se detectó que, aunque se habían definido diferentes VLANs para segmentar la red, estos segmentos tenían visibilidad directa entre ellos y no existía ningún control por el cual un usuario no administrador pueda llegar a la red por la cual se comunican los elementos críticos de la compañía **(SR-001, Existe una separación lógica entre la red de control y la red corporativa, con puntos de acceso mínimos y controlados para limitar los movimientos laterales y proteger los sistemas críticos)**.

Además, se detectó el uso de un protocolo inseguro para conectarse a la VPN, no existe una política para nombres de usuario y contraseñas **(CA-005, Se requiere una longitud mínima para las contraseñas)** no se discierne entre el usuario que es empleado y el que es proveedor, no se controlaba de ninguna manera las zonas a las cuales puede acceder cada usuario según su rol en la empresa **(CA-001, Existe un sistema de control de acceso basado en roles (RBAC) respaldado por políticas y procedimientos documentados)**.

Además, las redes IT y la OT no estaban correctamente aisladas, existiendo una gran superficie de ataque por la cual se podría llegar a comprometer parte de la red OT desde la red IT (como prueba se han podido leer registros de ciertos PLCs interrogando a un router industrial visible desde la red IT **(SR-002, Hay segmentación entre las redes OT e IT y se deniega la conexión a la red OT por defecto a menos que se permita explícitamente)**). Asimismo, varios elementos de la red mantenían versiones antiguas de firmware sin actualizar.

Otra vulnerabilidad era la ejecución remota de comandos a través de SMBv1 **(SR-010, Se garantiza que los activos conectados a la Internet pública no exponen servicios explotables innecesarios)**, y el acceso a un sistema SCADA debido a que la contraseña del administrador era la misma en los PCs de dos sedes diferentes. Los PLCs carecían de mecanismos de autenticación, falta de políticas de buenas prácticas debido a que una contraseña estaba escrita en un documento dentro de un PC de usuarios.

Tampoco se observaron sistemas de monitoreo y detección de actividades maliciosas que alerten al personal de la compañía para que estos puedan actuar en consecuencia **(SR-011, Se utilizan IDS/IPS basados en anomalías para detectar comportamientos inusuales)**.

En términos generales se puede concluir que no existían suficientes mecanismos de protección que podrían ser explotadas por un atacante y que podrían haberse enfrentado a riesgos tales como acceso no autorizado desde internet, compromiso de interfaces de administración remota, interceptación de comunicación internas, exposición a movimientos laterales, probabilidad de alterar directamente procesos industriales, acceso no autorizado por reutilización o filtración de contraseñas, riesgo de APT, exposición a exploits conocido debido al uso de firmware desactualizado, entre otros.

En este contexto, la realización temprana de un primer diagnóstico como el que se presenta en este documento habría permitido detectar y corregir estas deficiencias a tiempo, mejorando y fortaleciendo la postura de ciberseguridad de la organización y proporcionando una base sólida sobre la cual construir una estrategia de mejora continua en ciberseguridad para enfrentarse a futuras amenazas.

4.2. Caso de estudio 2 - Empresa de tratamiento de agua

Este caso de estudio describe un proyecto de ciber diagnóstico llevado a cabo en una planta de tratamiento de agua. El objetivo era obtener una visión clara de la postura de ciberseguridad de la empresa y proporcionar recomendaciones para mejorar su nivel de exposición a amenazas.

Aunque su infraestructura digital era esencial para las operaciones diarias, no contaban con políticas, controles ni roles definidos. Esas debilidades generaban una alta exposición a riesgos como accesos no autorizados, pérdida de datos, y posible interrupción de servicios críticos.

El diagnóstico reveló que la organización no había realizado nunca un análisis de riesgos en ciberseguridad y tampoco disponía de una estrategia de protección adecuada para sus activos.

Tras definir el alcance (**ámbito**) del ciber diagnóstico, se realizó una fase de **preparación**, donde se recopiló la información detallada de la infraestructura, incluyendo inventarios, políticas y mecanismos de control existentes y también se aportó información recopilada en fuentes públicas que pudieran aportar conocimientos útiles para la realización de un ciberataque en la infraestructura de la organización.

La fase de **evaluación** permitió identificar brechas críticas en las siguientes áreas:

- Máquinas y sistemas operativos, aplicaciones, y bibliotecas no actualizadas (**Seguridad de la red**)
- Falta de segmentación de red, sin subredes ni aislamiento de áreas críticas (**Seguridad de la red**)
- Servicios y puertos innecesarios expuestos a Internet (**Seguridad de la red**)
- Falta de privilegios mínimos (**Gobernanza**)
- Falta de un servidor de logs que centralice los logs de los dispositivos de red y servidores (**Control de Acceso**)
- No se restringía el acceso a los proveedores una vez realizadas las acciones que fueran necesarias (**Seguridad de la red**)
- No había listas de IP permitidas (**Seguridad de la red**)
- No se aplicaban restricciones a través de filtros MAC (**Seguridad de la red**)
- La información que se manejaba dentro de la organización no estaba categorizada por niveles de confidencialidad y por niveles de autorización (**Gobernanza**)
- No tenían políticas de contraseñas (**Gobernanza**)
- No tenían políticas de destrucción de documentación sensible (**Gobernanza**)
- No tenían políticas de uso adecuado de internet y sistemas corporativos (**Gobernanza**)
- El acceso a la sala del rack era libre y sin controles (**Control de Acceso – Seguridad física**)
- No tenían designado un responsable de ciberseguridad (**Gobernanza**)

- No disponían de política de usuarios y grupos en función del tipo de información a la que podrán acceder **(Gobernanza)**
- No disponían de un procedimiento para dar de alta/baja o modificar las cuentas de usuarios **(Gobernanza)**
- Falta de concienciación de personal **(Formación)**
- No se revisaban periódicamente los permisos concedidos a los usuarios **(Gobernanza)**
- No había políticas de revocación de permisos, eliminación de cuenta de correo **(Gobernanza)**
- No se bloqueaba el uso de USB externas **(Control de Acceso)**
- Los contratos con proveedores o terceros no estaban definidos **(Gobernanza)**
- No se realizaban planes de concienciación y de formación en ciberseguridad **(Formación)**

El diagnóstico nos permitió aprender varias lecciones. La primera es que la ausencia de controles básicos, como los que faltaban en este caso, puede generar una gran superficie de ataque. De hecho, la infraestructura se encontraba vulnerable a múltiples tipos de ataques como explotación de vulnerabilidades conocidas, accesos no autorizados (internos y externos), movimientos laterales internos. También la falta de formación del personal era crítica, tanto que tenían una baja capacidad de detección de amenazas y respuesta ante incidentes.

Otro punto para destacar, la carencia de un responsable de ciberseguridad y la falta de políticas y procedimientos.

Este caso demuestra que incluso en entornos sin estrategias ni madurez en ciberseguridad, el primer diagnóstico, o un auto diagnóstico pueden marcar la diferencia y ayudar a mitigar y prevenir riesgos y vulnerabilidades.

4.3. Caso de estudio 3 - Empresa de distribución de agua

El tercer caso de estudio se centra en una empresa del sector de distribución de agua. La dicha empresa contaba con una estrategia de ciber seguridad más avanzada respecto a los dos casos anteriores. También contaba con un inventario de activos detallado y una lista de buenas prácticas de mantenimiento preventivo.

Aun así, presentaba debilidades importantes en aspectos clave como gobernanza, formación y control de acceso.

Otro punto positivo para destacar era la monitorización continua para poder detectar problemas físicos o lógicos de elementos de la infraestructura (por ejemplo, los contadores de agua disponen de una pila que es monitorizada para controlar en qué momento debe ser cambiada).

El mantenimiento de los dispositivos se realizaba por parte de un proveedor mediante el cual disponen de sesiones quincenales y semanales en caso de incidencias. Para la tele lectura, se disponía de diferentes activos según el sistema utilizado.

Como debilidades importantes, se mencionan:

- La falta de un responsable de ciberseguridad
- No se disponía de un inventario del software relativo a cada uno de los activos que se ejecutan en la infraestructura, así como las versiones de este software
- No había un plan de gestión de riesgos de ciberseguridad,
- Los accesos a las dos salas de los servidores no tenían ninguna medida física de seguridad que impida a trabajadores sin rol concreto acceder a ellos.
- Se detectó la falta de políticas y procedimientos escritos, que describan y establezcan la manera de funcionar de la organización y que garanticen que se van a ejecutar los procesos de una manera similar en los distintos entornos, sedes o departamento de la organización.
- No se realizaban planes de concienciación o de formación en ciberseguridad
- No se habían establecido planes de continuidad y de recuperación. Debido a ello, había carencias en la identificación y asignación del impacto en la interrupción de cada activo y las consecuencias asociadas a la pérdida de cada uno de ellos, y carencia en la documentación de procedimientos de revisión, desarrollo, y gestión de crisis

Este caso nos enseña que contar con un buen inventario de activo es esencial, pero no suficiente. La empresa demostró tener visibilidad completa del hardware de su infraestructura, pero la falta de inventario de software limita el análisis de vulnerabilidades.

También la falta de procedimientos documentados aumenta el riesgo de errores y brechas. Además, se recomendó extender la monitorización a otras áreas como la detección de accesos no autorizados o alertas de comportamiento anómalo. Finalmente, la falta de capacitación del personal y la falta de

planes de continuidad y recuperación, dejan la organización expuesta ante incidentes que puedan comprometer tanto la operación como su reputación.

Este caso ayuda a entender que una infraestructura con un buen inventario y monitorización activa, además de una lista de buenas prácticas, debe complementarse con una gobernanza sólida, políticas claras y formación continua para poder evolucionar hacia una mejor postura de ciberseguridad. Con este diagnóstico, la empresa pudo comprender sus debilidades y empezar un camino hacia la protección de sus activos críticos y hacia una mejor gobernanza de la ciber seguridad.

5. Conclusiones

El presente documento ha presentado las tareas desarrolladas en el Bloque 2 del proyecto de **Apoyo ejecución acciones Cátedra INCIBE de Digitalización y Ciberseguridad Hídrica**.

En la **tarea 2.1 Investigación y desarrollo de la metodología**, se ha diseñado una metodología de autodiagnóstico de ciberseguridad específica para PYMES del sector, considerando su realidad operativa y sus recursos.

La metodología se fundamenta en estándares y marcos de referencia como el NIST CSF y la IEC62443, así como en las recomendaciones del Centro de Ciberseguridad Industrial y la directiva NIS2. Su estructura en cinco fases (Ámbito, Preparación, Evaluación, Plan de acción, Informe) y sus 90 controles seleccionados y agrupados en seis áreas clave, proporcionan un marco claro para la realización de un auto diagnóstico completo y eficaz.

La tarea 2.2, ha analizado tres casos de uso desarrollados por Eurecat, que documentan la aplicación de diagnósticos de ciberseguridad en empresas representativas del ciclo integral del agua, el tratamiento y la distribución, con distintos niveles de madures en ciberseguridad. Los resultados evidencian que la aplicación de una metodología como la propuesta en este documento, habría reducido de manera significativa las vulnerabilidades y debilidades detectadas por el equipo técnico de Eurecat.

El documento documenta también la tarea 2.3, donde se presenta una guía de aplicación que describe de manera detallada los pasos para implementar la metodología complementándola con una herramienta en formato Excel que facilita su adopción y permite a las PYMES llevar a cabo su propio diagnóstico de forma autónoma y estructurada.

En síntesis, el Bloque 2 del proyecto, ha generado una metodología práctica y alineada con estándares internacionales, acompañada de una herramienta y ejemplos reales que facilitan su aplicación y contribuyen a mejorar la ciberseguridad de las PYMES del sector agua.

Firmas

Realizado por:	Revisado por:
Giuseppe Sciuto Investigador UT IT&OT Security giuseppe.sciuto@eurecat.org	Mario Reyes de los Mozos Directos Científico UT IT&OT Security mario.reyes@eurecat.org

Bibliografía

- [1] “(PDF) CYBERSECURITY AND WATER UTILITIES: FACTORS FOR INFLUENCING EFFECTIVE CYBERSECURITY IMPLEMENTATION IN WATER SECTOR,” in *ResearchGate*, Accessed: Apr. 16, 2025. [Online]. Available: https://www.researchgate.net/publication/349849423_CYBERSECURITY_AND_WATER_UTILITIES_FACTORS_FOR_INFLUENCING_EFFECTIVE_CYBERSECURITY_IMPLEMENTATION_IN_WATER_SECTOR
- [2] “Aguas | INCIBE-CERT | INCIBE.” Accessed: Jun. 16, 2025. [Online]. Available: <https://www.incibe.es/incibe-cert/sectores-estrategicos/aguas>
- [3] CyberH2O, “La voz de los profesionales del agua sobre la ciberseguridad en las infraestructuras hídricas.” Accessed: Jul. 14, 2025. [Online]. Available: <https://cyberh2o.es/informe-de-la-voz-de-los-profesionales-del-agua-sobre-ciberseguridad/>
- [4] “EUROPA - Competition - List of NACE codes.” Accessed: Jun. 16, 2025. [Online]. Available: https://ec.europa.eu/competition/mergers/cases/index/nace_all.html#:~:text=C28.1.1%20ovens%2C%20furnaces%20and%20furnace%20burners
- [5] “Businesses in the water supply, sewerage, waste management and remediation sector.” Accessed: Jun. 16, 2025. [Online]. Available: https://ec.europa.eu/eurostat/statistics-explained/index.php?title=Businesses_in_the_water_supply,_sewerage,_waste_management_and_remediation_sector
- [6] Z. Agency, “About our sector.” Accessed: Jun. 16, 2025. [Online]. Available: <https://www.eureau.org/about/our-sector>
- [7] “https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA%20-%20NIS360%20-%202024_0.pdf.” Accessed: Jun. 16, 2025. [Online]. Available: https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA%20-%20NIS360%20-%202024_0.pdf
- [8] E. Kovacs, “EPA Issues Alert After Finding Critical Vulnerabilities in Drinking Water Systems,” *SecurityWeek*. Accessed: Jun. 16, 2025. [Online]. Available: <https://www.securityweek.com/epa-issues-alert-after-finding-critical-vulnerabilities-in-drinking-water-systems/>
- [9] A. Hassanzadeh *et al.*, “A Review of Cybersecurity Incidents in the Water Sector,” *J. Environ. Eng.*, vol. 146, no. 5, p. 03120003, May 2020, doi: 10.1061/(ASCE)EE.1943-7870.0001686.
- [10] S. Adepu, V. R. Palleti, G. Mishra, and A. Mathur, “Investigation of Cyber Attacks on a Water Distribution System,” Jun. 05, 2019, *arXiv*: arXiv:1906.02279. doi: 10.48550/arXiv.1906.02279.
- [11] “AWWACybersecurityRiskandResponsibility.pdf.” Accessed: Apr. 16, 2025. [Online]. Available: <https://www.waterisac.org/system/files/articles/AWWACybersecurityRiskandResponsibility.pdf>
- [12] “Maroochy Water Breach, Campaign C0020 | MITRE ATT&CK®.” Accessed: Jun. 16, 2025. [Online]. Available: <https://attack.mitre.org/campaigns/C0020/>
- [13] M. D. Abrams, “Malicious Control System Cyber Security Attack Case Study—Maroochy Water Services, Australia”.
- [14] “Cryptojacking | INCIBE | INCIBE.” Accessed: Jun. 16, 2025. [Online]. Available: <https://www.incibe.es/aprendeciberseguridad/cryptojacking>
- [15] S. M. Kerner, “Water Utility in Europe Hit by Cryptocurrency Malware Mining Attack,” *eWEEK*. Accessed: Jun. 16, 2025. [Online]. Available: <https://www.eweek.com/security/water-utility-in-europe-hit-by-cryptocurrency-malware-mining-attack/>

- [16] M. Lennon, "Cryptocurrency Mining Malware Hits Monitoring Systems at European Water Utility," SecurityWeek. Accessed: Jun. 16, 2025. [Online]. Available: <https://www.securityweek.com/cryptocurrency-mining-malware-hits-monitoring-systems-european-water-utility/>
- [17] "Updated: Top Cyber Actions for Securing Water Systems | CISA." Accessed: Jun. 16, 2025. [Online]. Available: <https://www.cisa.gov/news-events/alerts/2024/02/23/updated-top-cyber-actions-securing-water-systems>
- [18] "Estudio de incidentes OT de Alto Impacto: Sector Agua - Centro de Ciberseguridad Industrial." Accessed: Aug. 13, 2025. [Online]. Available: <https://www.cci-es.org/activities/estudio-de-incidentes-ot-de-alto-impacto-sector-agua/>
- [19] "Cybersecurity Framework," NIST, Nov. 2013, Accessed: Jul. 14, 2025. [Online]. Available: <https://www.nist.gov/cyberframework>
- [20] K. Stouffer *et al.*, "Guide to Operational Technology (OT) Security," National Institute of Standards and Technology, NIST Special Publication (SP) 800-82 Rev. 3, Sep. 2023. doi: 10.6028/NIST.SP.800-82r3.
- [21] "ISA/IEC 62443 Series of Standards - ISA," isa.org. Accessed: Jul. 14, 2025. [Online]. Available: <https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards>
- [22] prepared by W. Y. A. Awwa, "WATER SECTOR CYBERSECURITY RISK MANAGEMENT GUIDANCE".
- [23] O. US EPA, "EPA Cybersecurity for the Water Sector." Accessed: Aug. 13, 2025. [Online]. Available: <https://www.epa.gov/waterresilience/epa-cybersecurity-water-sector>
- [24] "WaterISAC's 12 Cybersecurity Fundamentals for Water and Wastewater Utilities – Release of Fundamentals 1-3," WaterISAC. Accessed: Apr. 30, 2025. [Online]. Available: <https://www.waterisac.org/portal/waterisacs-12-cybersecurity-fundamentals-water-and-wastewater-utilities-%E2%80%93-release>
- [25] "Directive - 2020/2184 - EN - EUR-Lex." Accessed: Jun. 16, 2025. [Online]. Available: <https://eur-lex.europa.eu/eli/dir/2020/2184/oj/eng>
- [26] "Directive - EU - 2024/3019 - EN - EUR-Lex." Accessed: Jun. 16, 2025. [Online]. Available: <https://eur-lex.europa.eu/eli/dir/2024/3019/oj/eng>
- [27] J. McCarthy, B. Stea, and D. Faatz, "Cybersecurity for the Water and Wastewater Sector".
- [28] "News - Incident Hub." Accessed: Jul. 13, 2025. [Online]. Available: <https://hub.tisafe.com/news/>
- [29] K. Stouffer *et al.*, "Guide to Operational Technology (OT) Security," National Institute of Standards and Technology, NIST Special Publication (SP) 800-82 Rev. 3, Sep. 2023. doi: 10.6028/NIST.SP.800-82r3.
- [30] "Centro de Ciberseguridad Industrial - Hazte miembro gratis." Accessed: Jul. 14, 2025. [Online]. Available: <https://www.cci-es.org/>
- [31] CyberH2O, "Informe: características esenciales de la NIS2 para el sector del agua." Accessed: Jul. 14, 2025. [Online]. Available: <https://cyberh2o.es/informe-caracteristicas-esenciales-de-la-nis2-para-el-sector-del-agua/>
- [32] "INICIO - Catalan Water Partnership." Accessed: Jul. 14, 2025. [Online]. Available: <https://cwp.cat/es/incio/>
- [33] "Taller de ciberseguridad aplicada al ciclo urbano del agua - Catalan Water Partnership." Accessed: Jul. 14, 2025. [Online]. Available: <https://cwp.cat/es/esdeveniment/taller-de-ciberseguridad-aplicada-al-ciclo-urbano-del-agua-2/>

- [34] CyberH2O, “Nuevo vídeo: gestión de la ciberseguridad hídrica, opinión de los profesionales.” Accessed: Jul. 14, 2025. [Online]. Available: <https://cyberh2o.es/nuevo-video-gestion-de-la-ciberseguridad-hidrica-opinion-de-los-profesionales/>
- [35] “Éxito en el Taller de Ciberseguridad Aplicada al Ciclo Urbano del Agua en Barcelona.” Accessed: Jul. 14, 2025. [Online]. Available: <https://cyberh2o.es/exito-en-el-taller-de-ciberseguridad-aplicada-al-ciclo-urbano-del-agua-en-barcelona/>
- [36] “Gobernanza de Ciberseguridad: La Clave para un Entorno Digital Seguro y Resiliente,” Kiteworks | Your Private Data Network. Accessed: May 23, 2025. [Online]. Available: <https://www.kiteworks.com/es/glosario-riesgo-cumplimiento/gobernanza-de-ciberseguridad/>
- [37] “Metodología para desarrollar un Inventario Esencial de Sistemas Industriales.” Accessed: Apr. 28, 2025. [Online]. Available: <https://nglibrary.cci-es.org/es/publications/34>
- [38] K. Stouffer *et al.*, “Guide to Operational Technology (OT) security,” National Institute of Standards and Technology (U.S.), Gaithersburg, MD, NIST SP 800-82r3, Sep. 2023. doi: 10.6028/NIST.SP.800-82r3.
- [39] “Talos IR - Incident Response Plan || Cisco Talos Intelligence Group - Comprehensive Threat Intelligence.” Accessed: Aug. 13, 2025. [Online]. Available: https://talosintelligence.com/incident_response/plans
- [40] “Plan de Respuesta a Incidentes de Ciberseguridad - Centro de Ciberseguridad Industrial.” Accessed: Aug. 13, 2025. [Online]. Available: <https://www.cci-es.org/plan-de-respuesta-a-incidentes-de-ciberseguridad/>
- [41] “Estableciendo Zonas y Conductos según el estándar ISA99/IEC62443 - Centro de Ciberseguridad Industrial.” Accessed: Aug. 14, 2025. [Online]. Available: <https://www.cci-es.org/activities/estableciendo-zonas-y-conductos-segun-el-estandar-isa99-iec62443/>
- [42] “PCS 7 Cyber Security Blueprint for Water Plants”.
- [43] J. McCarthy, B. Stea, and D. Faatz, “Cybersecurity for the Water and Wastewater Sector”.

Anexo I - Inventario y plantilla de inventario

Inventario

Este apartado explica cómo crear un primer inventario esencial de la infraestructura, que sirva como punto de partida para construir posteriormente un inventario más detallado y completo.

La correcta identificación de los activos de la propia infraestructura de agua es el primer paso para mejorar la ciberseguridad de la organización. Para eso es fundamental tener un inventario actualizado que permite conocer los activos que deben ser protegidos. Además, ayuda a priorizar esfuerzos de protección, detección y respuesta ante incidentes [37].

Es importante considerar que el desarrollo de un inventario de activos debe considerar el contexto y las capacidades específicas de cada organización. No es lo mismo una empresa que gestiona una red de distribución de agua para millones de personas que una PYME con una infraestructura mucho más pequeña. Las diferentes realidades de cada organización condicionan la realización y la gestión de un inventario de activos.

Las infraestructuras de agua, a menudo, presentan características específicas que deben ser consideradas a la hora de realizar un inventario: la presencia de **equipos muy antiguos** (PLC o sensores que ya no soportan actualizaciones); **redes segmentadas**, que limitan la visibilidad completa; **dispositivos industriales** que utilizan protocolos propietarios que dificultan la detección automática; **ambientes operativos** donde escaneos activos pueden afectar la operación[18].

Debido a estas particularidades se recomienda combinar una inspección física de la infraestructura (para identificar todos los dispositivos visibles) y un escaneo de red **pasivo** que permite observar el tráfico de red sin afectar los sistemas en operación.

En cuando a un escaneo **activo** de red se recomienda realizarlo solo si se dispone de personal técnico especializado en ciberseguridad o en el uso de herramientas de escaneo, ya que esta práctica debe ejecutarse con extrema precaución para evitar la interrupción de los sistemas industriales críticos.

Siguiendo las directrices de la norma IEC 62443, para cada activo, es importante registrar los siguientes datos:

Dato	Descripción
Identificador único	Una etiqueta única para cada activo, generalmente utilizando una nomenclatura que permita identificar qué tipo de activo se está inventariando
Nombre del activo	Nombre descriptivo del activo, indicando por ejemplo el tipo de activo y ubicación
Tipo de activo	Especificando si es hardware, software, dispositivo de red, personal de la planta, base de datos
Dirección IP/MAC	Datos de red en caso de activos conectados

Ubicación física	Indicar la ubicación física del activo, por ejemplo, Sala de control Girona, Estación de bombeo Salt, etc...
Estado	Si el dispositivo se encuentra activo, inactivo o en mantenimiento
Fecha de alta	Cuando se instaló el activo
Responsable asignado	La persona o área que gestiona ese activo
Última actualización conocida	Información sobre la última actualización de Firmware, software, o parches instalados
Medidas de seguridad implementadas	Los controles de seguridad ya implementados sobre el activo

Tabla 7. Datos inventario

Además es importante establecer un repositorio con información de proveedores, roles y responsabilidades para identificar a personas, equipos o grupos organizativos específicos que representen el responsable del activo[38].

De acuerdo con las recomendaciones del CCI, es importante adoptar las siguientes buenas prácticas en la gestión de un inventario [37]:

- Actualizar el inventario cada 6 meses o tras cada cambio importante
- Clasificarlo como documento reservado
- Limitar el acceso solo a personal autorizado
- Realizar copias de seguridad periódicas del inventario

Asimismo, el CCI, Debido a la amplitud que puede alcanzar un inventario completo, recomienda inicialmente realizar un inventario piloto de una pequeña área o proceso de la instalación aplicando la metodología en esta sección piloto; luego analizar los desafíos encontrados, corregir errores y mejorar el procedimiento para poder expandir progresivamente a toda la instalación[37].

Realizar y mantener un inventario de activos, proporciona unas ventajas importantes como:

- Facilita la identificación de vulnerabilidades y riesgos inherentes
- Ayuda a mantener información detallada de cada activo
- Permite evaluar la necesidad de actualizar los dispositivos y planificar sus cambios
- Permite identificar fallos
- Ayuda a mejorar los tiempos de respuestas ante incidentes

Ejemplo de datos generales de inventario:

Identificador	Nombre del Activo	Tipo de Activo	Descripción	Equipo/Ubicación	Nivel de la pirámide	Importancia del activo
SF01-L1-DO	Sensor de flujo	Hardware	Asegura que la cantidad correcta de producto se dosifique en los envases	Máquina dosificadora – Zona Proceso	0	Alta
SN01-L1-DO	Sensor de nivel	Hardware	Asegura que la cantidad correcta de producto se dosifique en los envases	Máquina dosificadora – Zona Proceso	0	Alta
AV01-L1-DO	Actuador válvula dosificadora	Hardware	Controla la apertura y cierre del flujo de producto hacia la máquina de llenado	Máquina dosificadora – Zona Proceso	0	Alta
PLC01-L1-DO	PLC dosificadora	Hardware	Coordina la dosificación según los parámetros establecidos	Máquina dosificadora – Zona Proceso	1	Alta
HMI01-L1-DO	HMI máquina dosificadora	Hardware	Supervisar el estado del equipo	Máquina dosificadora – Zona Proceso	2	Alta

Ilustración 11. Ejemplo de datos generales de inventario

Un inventario de activos es una tarea compleja que requiere organización, asignación de recursos y un enfoque estructurado como el que se propone y es uno de los fundamentos sobre el cual se construye una estrategia de ciberseguridad sólida.

Plantilla Inventario (ejemplo)

Activo	ID Activo	Descripción	Ubicación	Proceso	Responsable	Clasificación	Tipo	CID	Medidas implementadas
						Hardware			
						Software			
						Red			
						Personal			
						Organización			
						Información			
						Proveedores			
						Otro			

Anexo II - Plan de respuesta a incidentes y plantilla

Plan de respuesta a incidentes

Un plan de respuesta a incidentes es un documento operativo que define como la organización se prepara, detecta, contiene, erradica y se recupera ante incidentes que afecten a los sistemas IT y OT, minimizando el impacto sobre las personas, la continuidad operativa, la calidad del agua y el cumplimiento legal.

En entornos industriales, el plan de respuesta a incidentes debe ser específico para sistemas de control (SCADA, PLC, RTU, HMI, redes industriales) y contemplar sus restricciones operativas y de seguridad de proceso. Un error común es tratar la respuesta a incidentes como un elemento reactivo y final del programa de seguridad [39].

Un buen plan de RI debe[40]:

- Fijar alcance y objetivos, plantas, redes, sistemas críticos, dependencias
- Definir políticas y procedimientos para la gestión de incidentes y criterios de escalado
- Definir roles del equipo de respuesta y sus funciones
- Clasificar incidentes, estableciendo niveles de severidad (Crítico, Alto, Medio, Bajo) y tipos de incidente (malware, intrusión, insider, fallo de dispositivo, manipulación del PLC, etc)
- Documentar todo el proceso, preparación, detección, contención, erradicación, recuperación, lecciones aprendidas
- Incluir playbooks específicos para escenario como ransomware, manipulación de PLC, insider, compromiso de acceso remoto, entre otros
- Establecer comunicación y notificaciones
- Preservar evidencias
- Probar y actualizar el plan mediante simulacros y revisión post incidente

Según Talos Intelligence [39], estos son los errores a evitar al crear un plan de respuesta a incidentes:

- No definir una jerarquía documental y controles de versiones
- Ser demasiado general o demasiado específico
- Redactar en aislamiento, sin involucrar todos los departamentos
- No probar el plan de IR ni los playbooks
- No actualizar el plan tras cambios o incidentes
- Centrarse demasiado en el entorno IT, ignorando OT

Anexo III - Arquitectura de red segura: Segmentación y Microsegmentación de red

La arquitectura de red organiza como se conectan y protegen los sistemas de control industrial.

La segmentación consiste en dividir la red OT en **zonas** de seguridad con requisitos similares: zona de control, zona de servidores, zonas de ingeniería, etc., y controlar las comunicaciones entre zonas mediante **conductos** (firewall/ACL/VPN) con políticas explícitas [41].

La microsegmentación es aplicar esa separación dentro de cada **zona** (grupos de PLC safety, grupo de SCADA, armarios, celdas, etc) limitando flujos al mínimo necesario. Esta aproximación de zonas y **conductos** es la base de IEC 62443 [41].

En plantas de agua se recomienda separar las zonas cada una con controles y accesos propios, en [42]:

- Zona de operación/proceso
- Zona de ingeniería
- Zonas de servidores
- DMZ de operaciones
- Estaciones remotes
- Red corporativa

La IEC 62443 propone pasos prácticos sobre el diseño de una arquitectura segura [41]:

- Definir el Sistema bajo Consideración: límites, puntos de acceso
- Dividir en zonas y conductos, agrupando activos por función, ubicación, responsables y requisitos comunes de Seguridad e identificar los conductos necesarios
- Dibujar el diagrama de zonas y conductos
- Una arquitectura segura de referencia tendrá:
 - Zonas claramente identificadas y dispositivos de filtrado entre ellas
 - DMZ de operaciones como único punto de intercambio de datos IT-OT
 - Separación de ingeniería y operación en zona distintas
 - Prohibir el uso de multihomed (servidores con dos NIC en redes distintas)
 - Utilizar Firewall y enrutadores con política restrictiva

Los dispositivos mínimos necesarios son:

- Firewall Industriales en los límites de zona
- Jump server en la DMZ
- Routers para conectividad externa y a estaciones remotes

Buenas prácticas que propone el CCI:

- Deny-by-default, denegar todos los flujos de comunicación, y crear lista blanca de flujos permitidos entre zonas
- Eliminar la conexión directa entre IT y OT, utilizar una DMZ
- Eliminar servidores Dual-homed
- Cerrar líneas no gestionadas

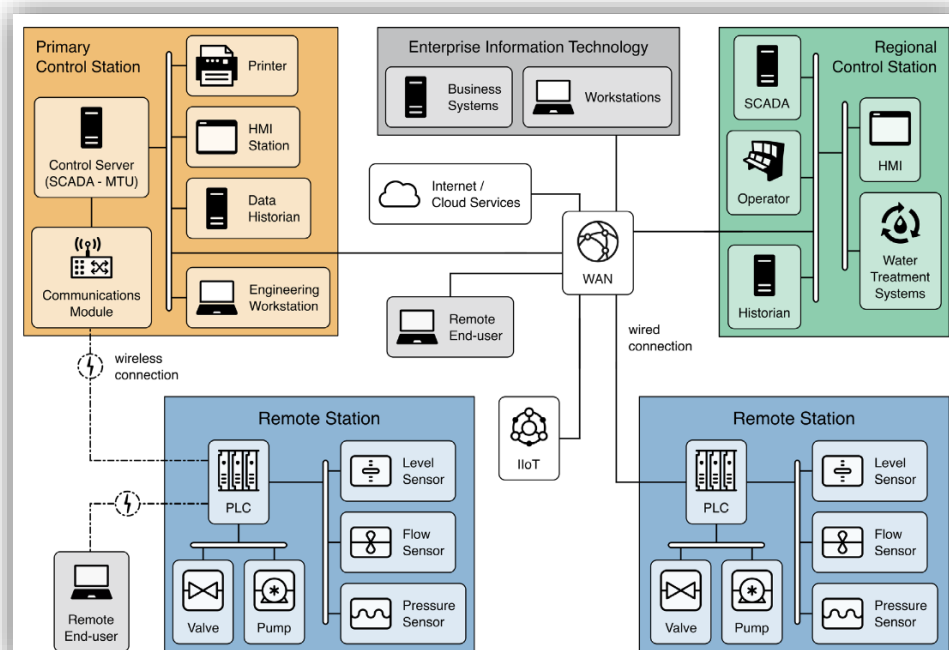


Ilustración 12. Ejemplo arquitectura segura [43]

Anexo IV - Marcos, estándares y guías de referencia para la ciberseguridad en el sector agua

Este anexo recopila los marcos, estándares y guías de referencia relevantes en materia de ciberseguridad para el sector agua.

Nombre	Descripción	Enlace
NIST CSF	NIST Cybersecurity Framework para la gestión de riesgos	https://www.nist.gov/cyberframework
NIST SP 800-82 Rev.3	Guía específica para OT con buenas prácticas técnicas y operativas para proteger el entorno OT	https://csrc.nist.gov/pubs/sp/800/82/r3/final
NIST NCCOE	Referencia práctica para mitigar los ciber riesgos en sistemas de agua potable y aguas residuales	https://www.nccoe.nist.gov/sites/default/files/2023-06/securing-water-and-wastewater-utilities-project-description-final.pdf
IEC 62443	Serie de normas para sistemas de automatización y control industrial	https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards
AWWA Cybersecurity Fundamentals	Guía para utilities de agua potable y aguas residuales en Estados Unidos, útil como guía sectorial	https://www.awwa.org/resource/cybersecurity-guidance/
NIS2	Directiva europea	https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng
EPA Cybersecurity	Programas y recursos oficiales para sistemas de agua en Estados Unidos, proporciona asistencia técnica, guías y alertas	https://www.epa.gov/waterresilience/epa-cybersecurity-water-sector
WaterISAC	Centro de intercambio de información para el sector agua	https://www.waterisac.org/

Control de cambios

Versión	Fecha	Apartado modificado	Descripción breve de la modificación
0	01/06/2025	Todos	Primera versión